B.Tech. BCSE497J - Project-I

CYBERTWIN: AN ADVERSARIAL PRIVACY DIGITAL TWIN WITH EVIDENCE-GROUNDED LLM AGENTS FOR PRE-RELEASE DATA AUDITING

Submitted in partial fulfillment of the requirements for the degree of

Bachelor of Technology

in

Computer Science and Engineering

by

23BCE2367	**UJJWAL ASATI**
23BDS0225	**KESHAV GUJRATHI**
23BDS0339	**CHUNDURI SAI KAUSHIK**

Under the Supervision of

Dr. Ranjithkumar S

Assistant Professor Sr. Grade 1

School of Computer Science and Engineering (SCOPE)



VIT®

Vellore Institute of Technology

(Deemed to be University under section 3 of UGC Act, 1956)

October 2026

DECLARATION

We hereby declare that the project entitled **CyberTwin: An Adversarial Privacy Digital Twin with Evidence-Grounded LLM Agents for Pre-Release Data Auditing** submitted by us, for the award of the degree of *Bachelor of Technology in Computer Science and Engineering* to VIT is a record of bonafide work carried out by us under the supervision of **Dr. Ranjithkumar S**.

We further declare that the work reported in this project has not been submitted and will not be submitted, either in part or in full, for the award of any other degree or diploma in this institute or any other institute or university.

Place : Vellore
Date : 21/10/2026

Ujjwal Asati	Chunduri Sai Kaushik	Keshav Gujrathi

Signature of the Candidates

CERTIFICATE

This is to certify that the project entitled **CyberTwin: An Adversarial Privacy Digital Twin with Evidence-Grounded LLM Agents for Pre-Release Data Auditing** submitted by **Ujjwal Asati (23BCE2367), Keshav Gujrathi (23BDS0225) and Chunduri Sai Kaushik (23BDS0339)**, **School of Computer Science and Engineering**, VIT, for the award of the degree of *Bachelor of Technology in Computer Science and Engineering*, is a record of bonafide work carried out by them under my supervision during Fall Semester 2026-2027, as per the VIT code of academic and research ethics.

The contents of this report have not been submitted and will not be submitted either in part or in full, for the award of any other degree or diploma in this institute or any other institute or university. The project fulfills the requirements and regulations of the University and in my opinion meets the necessary standards for submission.

Place : Vellore
Date : 21/10/2026

Signature of the Guide

Examiner(s)

Dr. Boominathan P, Dr. Sendhil Kumar K S
Computer Science and Engineering

ACKNOWLEDGEMENTS

We are deeply grateful to the management of Vellore Institute of Technology (VIT) for providing us with the opportunity and resources to undertake this project. Their commitment to fostering a conducive learning environment has been instrumental in our academic journey, and the support and infrastructure provided by VIT have enabled us to explore and develop our ideas to their fullest potential.

Our sincere thanks to Dr. Jaisankar N, the Dean of the School of Computer Science and Engineering (SCOPE), for his unwavering support and encouragement. His leadership and vision have greatly inspired us to strive for excellence, and his dedication to academic excellence and innovation has been a constant source of motivation.

We express my profound appreciation to Dr. Boominathan P and Dr. Sendhil Kumar K S, the Head of the Department of Software Systems and the Head of the Department of Database Systems respectively, for their insightful guidance and continuous support. Their expertise and advice have been crucial in shaping the direction of our project. The Head of Department's commitment to fostering a collaborative and supportive atmosphere has greatly enhanced our learning experience. Their constructive feedback and encouragement have been invaluable in overcoming challenges and achieving our project goals.

We are immensely thankful to our project guide, Dr. Ranjithkumar S, for his dedicated mentorship and invaluable feedback. His patience, knowledge and encouragement have been pivotal in the successful completion of this project, and his guidance has been instrumental in refining our ideas, our experiments and our papers.

Thank you all for your contributions and support.

Ujjwal Asati
Keshav Gujrathi
Chunduri Sai Kaushik

TABLE OF CONTENTS

Sl. No.	Contents	Page No.
	Abstract	x
1.	**INTRODUCTION**	1
	1.1 Background	1
	1.2 Motivations	1
	1.3 Scope of the Project	2
2.	**PROJECT DESCRIPTION AND GOALS**	3
	2.1 Literature Review	3
	2.1.1 Re-identification risk	3
	2.1.2 Syntactic privacy models	3
	2.1.3 Differential privacy and synthetic data	3
	2.1.4 Attacks on trained models	3
	2.1.5 LLM agents and factuality	3
	2.2 Research Gap	4
	2.3 Objectives	5
	2.4 Problem Statement	5
	2.5 Project Plan	6
3.	**TECHNICAL SPECIFICATION**	7
	3.1 Requirements	7
	3.1.1 Functional	7
	3.1.2 Non-Functional	8
	3.2 Feasibility Study	8
	3.2.1 Technical Feasibility	8
	3.2.2 Economic Feasibility	8
	3.2.3 Social Feasibility	8
	3.3 System Specification	9
	3.3.1 Hardware Specification	9
	3.3.2 Software Specification	9
4.	**DESIGN APPROACH AND DETAILS**	10
	4.1 System Architecture	10
	4.2 Design	11
	4.2.1 Data Flow Diagram	11
	4.2.2 Use Case Diagram	11
	4.2.3 Class Diagram	12
	4.2.4 Sequence Diagram	13
5.	**METHODOLOGY AND TESTING**	15

Sl. No.	Contents	Page No.
	5.1 Module Description	15
	5.1.1 Ingestion and schema inference	15
	5.1.2 Attack modules	15
	5.1.3 Defence modules	15
	5.1.4 Differential privacy module	16
	5.1.5 Compliance and document PII	16
	5.1.6 Agent layer	16
	5.2 Experimental Methodology	17
	5.3 Testing	18
6.	**PROJECT DEMONSTRATION**	20
	6.1 Dashboard	20
	6.2 Attack Lab	20
	6.3 Defense, Anonymization, Differential Privacy and Compliance Labs	23
	6.4 AI Agents: the Privacy Twin Loop	25
	6.5 Research Page	27
7.	**RESULT AND DISCUSSION**	29
	7.1 Experimental Results	29
	7.1.1 RQ1: How exposed are the releases?	29
	7.1.2 RQ2: What does k-anonymity cost?	29
	7.1.3 RQ3: What does the defence actually remove?	30
	7.1.4 RQ4: Does DP synthesis help?	31
	7.1.5 RQ5: Do trained models leak membership?	31
	7.1.6 RQ6: Can we predict the affordable k?	32
	7.1.7 RQ7: Can we trust the agents?	33
	7.2 Discussion	34
	7.3 Cost Analysis	35
8.	**CONCLUSION**	36
9.	**REFERENCES**	37
	APPENDIX A – SAMPLE CODE	42

List of Figures

Figure No.	Title	Page No.
2.1	Project timeline (Gantt chart)	6
4.1	System architecture of CyberTwin	10
4.2	Level-1 data flow diagram	11
4.3	Use case diagram	12
4.4	Class diagram of the agent layer and engine	13
4.5	Sequence diagram of a Privacy Twin run	14
6.1	Dashboard with system status, recent agent runs and activity log	20
6.2	Privacy Engine with the file uploaded and attacks selected	21
6.3	Attack results: scores, attack surface, uniqueness, de-anonymisation and ROC curves	22
6.4	Explainer agent output with per-card grounding badges	23
6.5	Defense Lab: proposed fix per column	24
6.6	Anonymization Lab: Mondrian with k = 5, ℓ = 2, t = 0.2, all 2,000 records kept	24
6.7	Differential Privacy lab: PrivBayes at ε = 1 with fidelity, TSTR accuracy and DCR	25
6.8	Compliance pre-assessment: HIPAA Safe Harbor, GDPR and DPDP Act 2023	25
6.9	Live reasoning trace of the red-team agent (gpt-oss-120b, free tier)	26
6.10	Privacy Twin scorecard: the same attacks on the original and on the released table	26
6.11	Threat Orchestrator verdict with evidence check and grounding badge	27
6.12	Optimization & Verification agent: negotiated constraints, Pareto front and re-attack	27
6.13	Research page showing experiment E1	28
7.1	(a) Unique records as the attacker learns more QIs; (b) smaller samples are more identifying	29
7.2	NCP and downstream random-forest accuracy versus k (accuracy averaged over 5 seeds)	30
7.3	Mean Friedman ranks over 30 (dataset, k) blocks with the Nemenyi critical difference (CD)	30
7.4	DP synthesis versus ε: two-way TVD, TSTR gain over the majority class, and DCR share	31
7.5	Membership-inference ROC curves for default and regularised random forests	32
7.6	Adaptive forecaster: accuracy of the recommended k	33
7.7	(a) Audits each pinned free-tier model completed; (b) verdict agreement with evidence (95% Wilson CIs)	34

List of Tables

Table No.	Title	Page No.
2.1	Summary of key literature	4
2.2	Project phases and deliverables	6
3.1	Functional requirements	7
3.2	Non-functional requirements	8
3.3	Hardware specification	9
3.4	Software specification	9
5.1	Benchmark datasets and attacker models (QIs: attributes the adversary is assumed to know)	17
5.2	Automated test suites	18
5.3	Representative test cases	18
7.1	Baseline re-identification risk under the stated attacker models	29
7.2	Mondrian versus full-domain (FD) generalisation: paired Wilcoxon tests, Holm-corrected	30
7.3	Summary across the five benchmarks (* differs from original or still > 0.5, Holm $p < 0.05$)	31
7.4	Membership inference (10 seeds): shadow-model AUC, TPR at 1% FPR and test accuracy	32
7.5	Forecasting the largest affordable k on 60 real-derived tasks (leave-one-dataset-out)	33
7.6	Threat Orchestrator audits on six datasets, each LLM run pinned to one free-tier model	33
7.7	Grounding verifier: value-only versus attribute-bound matching on identical planted faults	34
7.8	Cost analysis	35

List of Abbreviations

AIM	Adaptive and Iterative Mechanism (DP synthesizer)
API	Application Programming Interface
AUC	Area Under the ROC Curve
CD	Critical Difference (Nemenyi test)
CI	Confidence Interval / Continuous Integration
CSV	Comma-Separated Values
DCR	Distance to Closest Record
DFD	Data Flow Diagram
DP	Differential Privacy
DPDP	Digital Personal Data Protection (Act, 2023)
EMD	Earth Mover's Distance
FD	Full-Domain (generalisation)
FPR	False-Positive Rate
GDPR	General Data Protection Regulation
HIPAA	Health Insurance Portability and Accountability Act
HMAC	Hash-based Message Authentication Code
JSON	JavaScript Object Notation
LLM	Large Language Model
LODO	Leave-One-Dataset-Out
MIA	Membership Inference Attack
MST	Maximum Spanning Tree (DP synthesizer)
NCP	Normalised Certainty Penalty
PAN	Permanent Account Number
PII	Personally Identifiable Information
QI	Quasi-Identifier
ReAct	Reasoning and Acting (agent pattern)
REST	Representational State Transfer
RF	Random Forest
ROC	Receiver Operating Characteristic
SDG	Sustainable Development Goal
TPR	True-Positive Rate
TSTR	Train on Synthetic, Test on Real
TVD	Total Variation Distance
UCI	University of California, Irvine (ML Repository)
UI	User Interface

Symbols and Notations

k	Minimum equivalence-class size (k-anonymity)
ℓ	Minimum distinct sensitive values per class (ℓ-diversity)
t	Maximum distance between class and table distributions (t-closeness)
ε	Privacy-loss budget (differential privacy)
n	Number of records
m	Number of quasi-identifiers known to the attacker
P_r	Prosecutor re-identification risk, 1/|class|
τ	Risk threshold for "at-risk" records
a, a_0	Attacker accuracy and majority-class baseline accuracy
$E[1/\|C\|]$	Expected de-anonymisation success over candidate sets C
χ^2	Chi-square / Friedman test statistic
p	p-value

ABSTRACT

Organisations routinely share tables after deleting names and e-mail addresses, assuming that what remains is anonymous. On the Adult census benchmark, however, 47.5% of people can still be singled out from ordinary attributes such as age, occupation and education. Checking this properly means acting as the attacker, and few teams have the tools or the time to do so.

This project presents **CyberTwin**, an open-source adversarial privacy digital twin for tabular data releases. CyberTwin attacks a candidate release with reconnaissance, linkage, de-anonymisation, attribute-inference and membership-inference attacks; protects it with column-level fixes, Mondrian or full-domain k-anonymity (optionally with ℓ-diversity and t-closeness) or ε-differentially private synthetic data; and then runs the same attacks again on what would actually be published, producing a before/after scorecard and a certificate. Large language model (LLM) agents drive this loop using free-tier models only: a red-team Threat Orchestrator, a blue-team Optimization & Verification agent, an Adaptive agent that forecasts how much privacy a dataset can afford, and an Explainer. Two safeguards keep the agents honest. An **evidence gate** refuses a verdict until the attacks it depends on have been run, and an **attribute-bound grounding verifier** checks that every number an agent writes matches the tool output for the same metric.

We evaluated the system on five public datasets with explicit attacker models, using paired tests with Holm correction. Every dataset was re-identifiable. Mondrian lost less information and kept more downstream accuracy than full-domain generalisation in every comparison (Friedman $p < 10^{-4}$). Yet k-anonymity reduced attribute inference on only one of three datasets where inference was possible, default random forests leaked membership on all five (shadow AUC 0.64–0.94), and simple independent noisy marginals matched or beat two tree-based DP synthesizers. In 42 agent audits, the three free models finished between 4 and 11 of their 12 audits without help (χ^2 $p = 0.008$). When they finished, they matched the evidence in 22 of 24 cases; both mistakes understated the risk and both followed skipped attacks (Fisher $p = 0.022$). On held-out traces the grounding verifier caught 96.5% of planted false numbers and 71% of numbers swapped in from a different metric, against 0.7% for plain value matching, with no false alarms.

The system is a three-tier web application (React, Node.js/Express, Python/Flask) with 153 automated tests, and the research is written up as an IEEE conference paper and an Elsevier journal paper.

Keywords: *anonymisation, re-identification, k-anonymity, differential privacy, membership inference, LLM agents, hallucination, digital twin.*

CHAPTER 1

1. INTRODUCTION

1.1 Background

Organisations share tables all the time. Hospitals send patient extracts to researchers, banks hand customer records to analytics vendors, and government departments publish open data. Before a table leaves the building, someone usually removes the obvious identifiers such as names, e-mail addresses and phone numbers, and the table is then described as anonymous. The trouble is that the remaining columns are often enough to single people out. Sweeney showed that most residents of the United States could be identified from ZIP code, sex and date of birth alone [1], [2]. Narayanan and Shmatikov re-identified Netflix subscribers from a handful of approximate movie ratings [3], and Rocher et al. estimated that 15 demographic attributes are enough to re-identify 99.98% of Americans in any dataset [4]. A systematic review of attacks on health data reached the same conclusion: removing direct identifiers is not the same as anonymisation [5].

The research community has produced a long list of defences. Syntactic models such as k-anonymity [6], [7], ℓ-diversity [8] and t-closeness [9] generalise the attributes an attacker might know, so that every record hides in a crowd. Differential privacy (DP) [10], [11] instead adds calibrated noise and can be used to release synthetic tables [12], [13], [14]. Machine-learning models trained on personal data can themselves leak whether a person was in the training set [15], [16], [17]. Regulation has followed: the GDPR distinguishes anonymous data from pseudonymous data [18], the HIPAA Safe Harbor rule lists eighteen identifiers that must be removed [19], and India's Digital Personal Data Protection (DPDP) Act 2023 applies to any data about an identifiable person [20].

Large language models (LLMs) have recently been used as agents that plan and call tools, for example in automated penetration testing [21]. They could make a privacy audit much easier to run, but they are also known to state numbers and facts that are not supported by any source [22]. In a privacy audit that is dangerous: an agent that confidently reports "low risk" for a table full of unique records gives false comfort to exactly the person who needs a warning.

1.2 Motivations

This project started from a simple observation. The defences above are well understood [23], yet the people who release data rarely use them with confidence. Three practical problems stand in the way.

- **Tools are separate.** Attack tools, anonymisation tools and synthetic-data tools live in different libraries. A team that applies *k*-anonymity seldom attacks its own output to see what still leaks.
- **Parameters are guesswork.** The same k, ℓ, t or ε costs very different amounts of information on different tables, and there is no quick way to know in advance what a dataset can afford.
- **AI assistants are not trustworthy by default.** LLMs can explain risk in plain language, but they make up numbers and can skip the very analysis their verdict depends on [24].

We wanted a single tool that behaves like an attacker you hire before you publish: it attacks the table, protects it, and then attacks the protected copy again with the same tools, so that the

improvement is measured rather than assumed. We also wanted to find out, with proper experiments, whether free LLMs can be trusted to run such an audit, and what guard rails they need.

1.3 Scope of the Project

The project, called **CyberTwin**, is an adversarial privacy digital twin for tabular data releases. Its scope is as follows.

- **Inputs:** tabular files (CSV, Excel .xlsx/.xls, JSON) up to 50 MB for the full attack-and-protect toolkit, and documents (PDF, Word .docx, TXT) for personal-data scanning and redaction.
- **Attacks:** reconnaissance and prosecutor risk, linkage, de-anonymisation with noisy background knowledge, attribute inference, and membership inference against a trained model.
- **Defences:** column-level fixes (generalise, mask, keyed pseudonyms, suppress), *k*-anonymity by Mondrian or full-domain generalisation with optional ℓ-diversity and *t*-closeness, and ε-differentially private synthetic data.
- **Agents:** a red-team Threat Orchestrator, a blue-team Optimization & Verification agent, an Adaptive forecasting agent and an Explainer, all running on free-tier LLMs with a deterministic fallback.
- **Compliance triage:** pre-checks against HIPAA Safe Harbor, GDPR and the DPDP Act 2023. These are engineering aids, not legal advice.
- **Research:** seven reproducible experiments (E1–E7) on five public datasets, with significance testing, written up as an IEEE conference paper and an Elsevier journal paper.

Longitudinal, graph and free-text re-identification, optical character recognition for scanned PDFs and multi-user authentication are outside the scope of this phase.

CHAPTER 2

2. PROJECT DESCRIPTION AND GOALS

2.1 Literature Review

We reviewed work in five areas that the project draws on. Table 2.1 summarises the most important papers.

2.1.1 Re-identification risk

Sweeney's early study [1] and Golle's re-examination [2] established that a few demographic attributes are often unique. Narayanan and Shmatikov showed that sparse, high-dimensional data are even easier to de-anonymise [3]. Rocher et al. modelled uniqueness with copulas and showed that releasing only a sample does not protect people [4], and later argued that anonymisation must be judged against concrete attacks [25]. El Emam and Dankar formalised prosecutor, journalist and marketer risk for health data [26]. CyberTwin's reconnaissance, linkage and de-anonymisation attacks implement these risk measures directly.

2.1.2 Syntactic privacy models

k-anonymity requires every record to share its quasi-identifier (QI) values with at least $k-1$ others [6], [7]. It does not stop an attacker from learning a sensitive value when all records in a class share it, which motivated ℓ-diversity [8], and it does not stop skewed classes from leaking information, which motivated t-closeness [9]. Full-domain generalisation applies one hierarchy level to the whole column [6], [27]; Mondrian instead partitions the QI space recursively at medians [28]. Information loss is measured by the normalised certainty penalty (NCP) [29] and the discernibility metric [27]. Slijepčević et al. measured how generalisation affects classifiers [30].

2.1.3 Differential privacy and synthetic data

Differential privacy bounds how much any one record can change the output of an analysis [10], [11]. PrivBayes learns a Bayesian network under DP and samples synthetic records from it [12]. MST, which won the NIST synthetic-data challenge, measures noisy two-way marginals selected by a maximum spanning tree [13], and AIM adaptively selects higher-order marginals [14]. Stadler et al. warn that synthetic data is not automatically private and should be tested with attacks [31]. DP-SGD brings the same guarantee to deep learning [32].

2.1.4 Attacks on trained models

Shokri et al. introduced shadow-model membership inference [15]; Yeom et al. linked membership leakage to overfitting and proposed a simple confidence-threshold attack [16]; Carlini et al. argued that attacks should be judged by their true-positive rate at a low false-positive rate rather than by average accuracy [17]. Model inversion can recover sensitive attributes from a model's confidence scores [33].

2.1.5 LLM agents and factuality

ReAct interleaves reasoning steps with tool calls [34], and Toolformer showed that models can learn when to call tools [35]. PentestGPT applied LLM agents to security testing [21]. Hallucination remains the main obstacle [22]: LLMs struggle to correct their own reasoning without external feedback [24], LLM judges need careful calibration [36], and FActScore breaks long text into atomic facts that can be verified against a knowledge source [37]. Our grounding verifier applies the same idea in a narrow domain, where the knowledge source is the agent's own tool output.

Table 2.1 Summary of key literature

Paper	Objective	Methodology	Pros / Cons	Findings
Sweeney [7]	Protect records against linkage	*k*-anonymity via generalisation and suppression	+ simple, auditable; − ignores attribute disclosure	Each record hides among *k* others
Machanavajjhala *et al.* [8]	Stop homogeneity attacks	ℓ distinct sensitive values per class	+ blocks homogeneity; − ignores skew	*k*-anonymous tables still leak sensitive values
Li *et al.* [9]	Limit distribution skew	EMD between class and table distributions	+ stronger semantics; − high utility cost	ℓ-diversity is insufficient under skew
LeFevre *et al.* [28]	Reduce information loss	Multidimensional median partitioning (Mondrian)	+ fast, low NCP; − non-uniform recoding	Better utility than single-dimension recoding
Rocher *et al.* [4]	Estimate re-identification likelihood	Gaussian-copula uniqueness model	+ works on samples; − needs population model	15 attributes identify 99.98% of Americans
Zhang *et al.* [12]	DP synthetic data	DP Bayesian network + noisy conditionals	+ captures correlations; − budget split	Better than independent noise in their tests
McKenna *et al.* [13]	Scalable DP synthesis	Noisy 2-way marginals on a spanning tree (MST)	+ won NIST contest; − limited to selected pairs	High fidelity on census data
Shokri *et al.* [15]	Detect training-set membership	Shadow models mimic the target	+ black-box; − needs similar data	Overfitted models leak membership
Carlini *et al.* [17]	Fair evaluation of MIA	Likelihood-ratio attack, TPR at low FPR	+ realistic metric; − many shadow models	Average accuracy hides real risk
Stadler *et al.* [31]	Test privacy of synthetic data	Linkage and inference attacks on synthesizers	+ empirical; − attack-specific	Synthetic data is not private by default
Yao *et al.* [34]	Tool-using LLM agents	Interleaved reasoning and acting (ReAct)	+ interpretable traces; − error propagation	Better task success than chain-of-thought
Min *et al.* [37]	Measure factual precision	Atomic facts checked against a source	+ fine-grained; − needs retrieval source	LLM biographies contain many unsupported facts

2.2 Research Gap

From the review we identified five gaps that this project addresses.

1. **No closed loop.** Existing tools either attack or defend. None re-runs the same attacks on the protected release and reports what changed and what did not.
2. **No guard rails for LLM auditors.** Agent frameworks let an LLM decide which tools to run, but nothing forces it to run the analyses its verdict depends on, and nothing checks that each number it writes belongs to the metric it claims to describe.
3. **No measured comparison of free LLMs as auditors.** We found no study that separates *whether* a free model finishes an audit from *whether* its verdict is right.
4. **Benchmarks without explicit attacker models or corrected statistics.** Many comparisons of anonymisation methods infer quasi-identifiers heuristically, use one seed and report no significance tests.
5. **No advance estimate of cost.** A data owner cannot tell in advance how much information a given k will cost on a new dataset.

2.3 Objectives

1. Build a closed attack → protect → re-attack loop that reports before/after metrics for every release.
2. Implement five attacks (reconnaissance, linkage, de-anonymisation, attribute inference, membership inference) and three families of defences (column fixes, Mondrian / full-domain k-anonymity with ℓ and t, DP synthesis).
3. Design LLM agents on free-tier models only, and add two safeguards: an evidence gate and an attribute-bound numeric grounding verifier.
4. Benchmark the defences on five public datasets with explicit attacker models, multiple seeds and multiple-comparison correction.
5. Measure how reliable free LLMs are as privacy auditors, and how well the grounding verifier catches planted false numbers.
6. Forecast the strongest k a new dataset can afford, and test the forecast on held-out real data.
7. Deliver a tested, production-structured web application and publish the work as a conference paper and a journal paper.

Sustainable Development Goals. The project supports SDG 16 (Peace, Justice and Strong Institutions; target 16.10 on protecting fundamental freedoms, including privacy) and SDG 9 (Industry, Innovation and Infrastructure), because it lowers the cost of releasing data safely for research and innovation. **Outcomes:** one conference paper and one journal paper (drafts complete), and an open-source tool under the MIT licence.

2.4 Problem Statement

Given a table that a data owner intends to release and a description of what an attacker might already know, measure how identifiable the people in it are, produce a protected version that

meets a stated privacy goal at the lowest information cost, and prove the improvement by attacking the protected version again. Where LLM agents are used to plan and explain the audit, ensure that their verdicts rest on evidence that was actually computed and that every number they report is faithful to that evidence.

2.5 Project Plan

The work was carried out in eight overlapping phases between July and October 2026 (Fig. 2.1 and Table 2.2). Engine development and agent development overlapped deliberately, because the agents' tool interface had to be designed together with the engine's API.

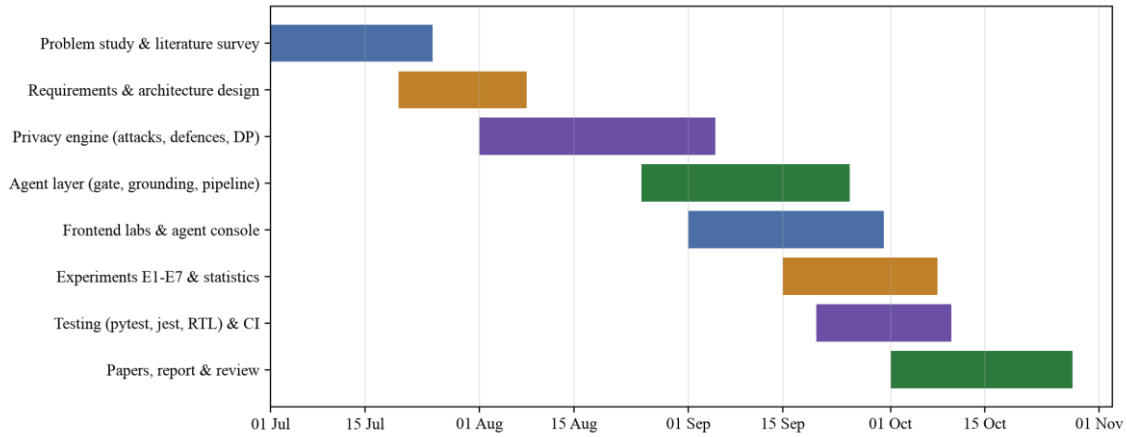


Fig. 2.1 Project timeline (Gantt chart)

Table 2.2 Project phases and deliverables

#	Phase	Period	Deliverable
1	Problem study and literature survey	Jul 2026	Survey of 55 references, research gap
2	Requirements and architecture	Jul–Aug 2026	Three-tier design, API contract
3	Privacy engine	Aug–Sep 2026	Attacks, defences, DP synthesis, compliance, document PII
4	Agent layer	Aug–Sep 2026	Orchestrator, optimizer, adaptive, explainer, gate, verifier
5	Frontend	Sep 2026	Labs, agent console, reports, research page
6	Experiments E1–E7	Sep–Oct 2026	Results, figures, statistical tests
7	Testing and CI	Sep–Oct 2026	153 automated tests, GitHub Actions workflow
8	Papers, report, reviews	Oct 2026	IEEE and Elsevier manuscripts, this report

CHAPTER 3

3. TECHNICAL SPECIFICATION

3.1 Requirements

3.1.1 Functional

Table 3.1 Functional requirements

ID	Requirement	Description
FR1	Data ingestion	Accept CSV, XLSX, XLS and JSON tables and PDF, DOCX and TXT documents up to 50 MB; infer a schema with identifiers, quasi-identifiers and sensitive attributes, or accept an explicit attacker model.
FR2	Reconnaissance	Report sample uniqueness, *k*, prosecutor risk and a composite risk index whose components are shown.
FR3	Linkage attack	Measure uniqueness as the attacker learns 1…*m* QIs and simulate a join with an external table.
FR4	De-anonymisation	Strip identifiers and search with noisy background knowledge; report expected success E[1/|C|] and exact matches.
FR5	Attribute inference	Train a classifier on the QIs and report the normalised advantage over the majority baseline.
FR6	Membership inference	Run confidence-threshold and shadow-model attacks; report ROC AUC and TPR at 1% FPR.
FR7	Column defences	Generalise, mask, pseudonymise (keyed HMAC) or suppress columns and re-score risk round by round.
FR8	Anonymisation	*k*-anonymity by Mondrian or full-domain generalisation, optional ℓ-diversity and *t*-closeness, with NCP, discernibility and record retention.
FR9	DP synthesis	Generate ε-DP synthetic data (independent marginals, PrivBayes; MST and AIM in the research harness) and report fidelity (TVD), utility (TSTR) and copying (DCR).
FR10	Compliance triage	Check HIPAA Safe Harbor (18 identifiers), GDPR and DPDP Act 2023 indicators.
FR11	Document PII	Detect and redact names, e-mails, phones, Aadhaar (Verhoeff checksum), PAN and card numbers (Luhn).
FR12	AI agents	Run the Threat Orchestrator, Optimization & Verification agent, Adaptive agent and the full Privacy Twin pipeline with a live reasoning trace.
FR13	Safeguards	Enforce the evidence gate and check every number in agent text against tool output, bound to its metric.
FR14	Reporting	Produce PDF and JSON certificates for every run and display research results.

3.1.2 Non-Functional

Table 3.2 Non-functional requirements

Attribute	Requirement and how it is met
Privacy by design	Uploaded files get random names and are deleted after use; database credentials are used once and never stored; LLM prompts carry aggregate metrics only, never records.
Reproducibility	All engine randomness is seeded; experiments record seeds, attacker models and dataset provenance (MANIFEST.json).
Reliability	LLM calls fall back across free models and retry malformed tool calls; with no key a deterministic expert policy completes every task.
Performance	Long agent runs execute as background jobs with polling; models train on at most 20,000 rows; the engine runs under gunicorn with worker threads.
Cost	Only free-tier LLM APIs (Groq, optional Gemini); open-source dependencies only.
Maintainability	Three separately testable tiers, central error handling, configuration through environment variables, 153 automated tests and a CI workflow.
Security	Input validation with 400 responses for client errors, file-type allow-list, size limits, rate limit on agent runs (AGENT_RUNS_PER_HOUR), secrets kept out of version control.
Usability	One upload shared by all labs, plain-English explanations, before/after scorecards and downloadable certificates.

3.2 Feasibility Study

3.2.1 Technical Feasibility

All components are built on mature open-source libraries: pandas and scikit-learn for data handling and models, OpenDP SmartNoise [38] for MST and AIM, Flask and gunicorn for the engine, Express for the gateway, and React for the interface. The privacy algorithms are well documented in the literature and were implemented and unit-tested against small worked examples. The only external dependency at run time is an LLM API, and the system remains fully functional without it. The full experiment suite runs on a laptop in about 75 minutes.

3.2.2 Economic Feasibility

The project has no licence or API cost. Every library is open source and every LLM call goes to a free tier. Development used the team's own laptops. Commercial privacy-engineering platforms are typically sold on enterprise licences; CyberTwin offers the core audit loop at no cost, which makes it usable by universities, start-ups and public bodies. A detailed cost analysis is given in Section 7.3.

3.2.3 Social Feasibility

Better release checks protect the people in a dataset from discrimination, fraud and embarrassment, and help organisations meet the DPDP Act 2023. The tool explains risk in plain language, so it can be used by data owners who are not privacy specialists. Attacks run locally on data the user supplies, and the synthetic demonstration table describes no real person, so the tool itself does not create new privacy harm.

3.3 System Specification

3.3.1 Hardware Specification

Table 3.3 Hardware specification

Component	Minimum	Used in development
Processor	4-core x86-64 or ARM64	Apple silicon (ARM64), 8+ cores
Memory	8 GB RAM	16 GB RAM
Storage	5 GB free (datasets and dependencies)	SSD
Network	Internet for LLM APIs (optional)	Broadband
GPU	Not required	Not used

3.3.2 Software Specification

Table 3.4 Software specification

Layer	Software
Operating system	macOS, Linux or Windows (WSL)
Privacy engine	Python 3.10+, Flask, gunicorn, pandas, NumPy, scikit-learn, SciPy, OpenDP SmartNoise, pdfplumber, python-docx, openpyxl, xlrd
Gateway and agents	Node.js 18+, Express, multer, axios, Groq / Gemini REST APIs
Frontend	React 18, Tailwind CSS, Recharts, React Flow, lucide-react
Testing	pytest, Jest, Supertest, React Testing Library, GitHub Actions
Research	Matplotlib, SciPy statistics, LaTeX (Tectonic) with IEEEtran and elsarticle
LLMs (free tier)	openai/gpt-oss-120b, openai/gpt-oss-20b, qwen/qwen3.8-27b on Groq; optional Gemini

CHAPTER 4

4. DESIGN APPROACH AND DETAILS

4.1 System Architecture

CyberTwin has three tiers (Fig. 4.1). The **presentation tier** is a React single-page application with a dashboard, the Privacy Engine labs, the AI agent console, reports and the research page. The **application tier** is a Node.js/Express gateway that exposes REST routes, runs long agent jobs in a queue, keeps an audit log and the adaptive agent's memory, and hosts the agent layer and the LLM service. The **computation tier** is a Python/Flask engine, served by gunicorn, that performs all privacy computation. The tiers talk over JSON and multipart REST calls, so each can be tested and deployed on its own.

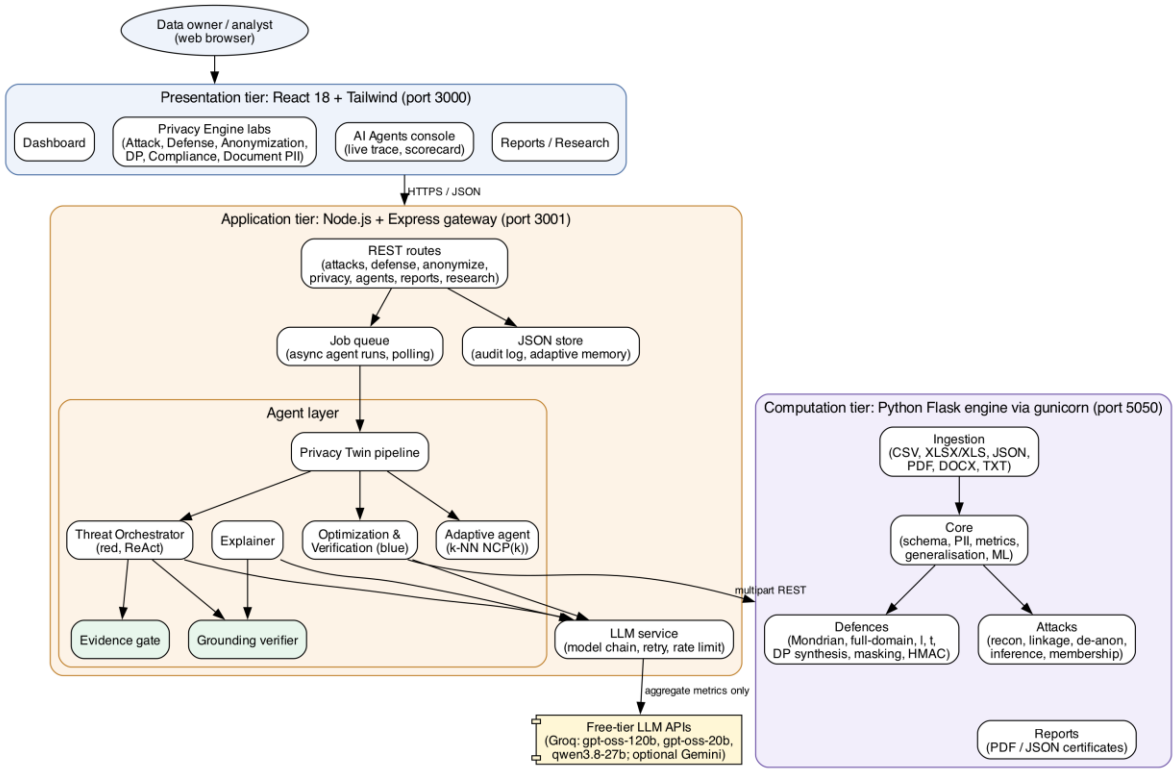


Fig. 4.1 System architecture of CyberTwin

The design follows one rule throughout: **agents decide, the engine computes.** An LLM never computes a privacy metric itself; it chooses which engine tool to call next and writes explanations, and both choices are checked. The **Privacy Twin pipeline** chains the agents into a closed loop:

1. The red-team **Threat Orchestrator** audits the original table with a ReAct loop over ten tools.
2. The **evidence gate** runs any required attack the agent skipped (reconnaissance, and linkage when QIs exist) before the verdict is accepted.
3. The **Adaptive agent** forecasts the information-loss curve NCP(k) from similar past datasets and recommends the strongest affordable k.

4. The blue-team **Optimization & Verification agent** turns the plain-language goal into $k/\ell/t$ constraints, searches the privacy–utility Pareto front and relaxes t, then ℓ (never k) if nothing is feasible.
5. The release is **attacked again** with the same tools, and a before/after scorecard and certificate are produced.

4.2 Design

4.2.1 Data Flow Diagram

Fig. 4.2 shows the level-1 data flow. Uploaded files are held only in a temporary store (D1) during processing. Only aggregate metrics flow to the external LLM provider. Scored outcomes are written to the adaptive memory (D2) so that later forecasts improve, and every run is logged (D3).

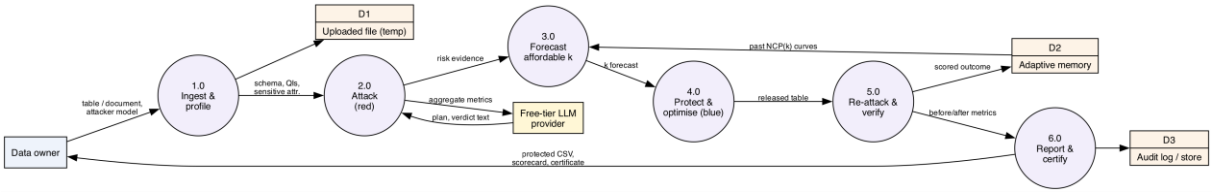


Fig. 4.2 Level-1 data flow diagram

4.2.2 Use Case Diagram

There are two human actors (Fig. 4.3). A **data owner** uploads data, runs attacks and defences, and downloads the protected release and its certificate. A **privacy analyst or researcher** runs attacks and agent audits and inspects research results. The external LLM provider is a secondary actor used only by the agent use case, which always includes verification of the agent's claims.

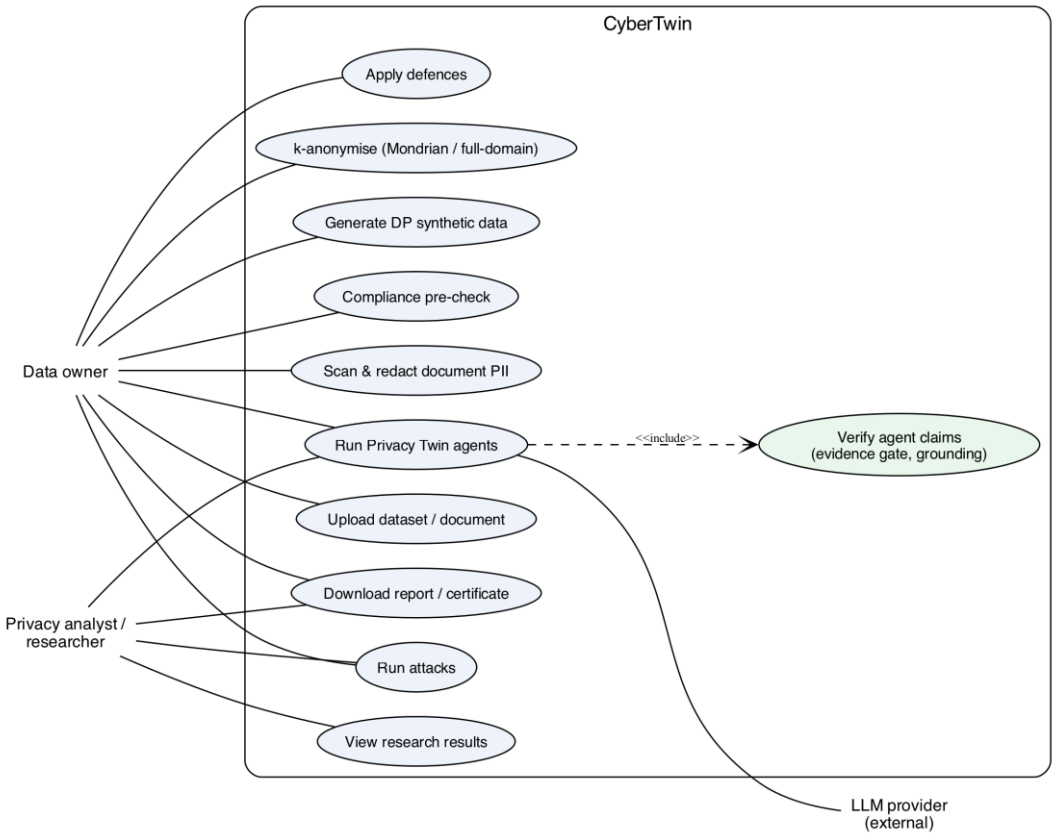


Fig. 4.3 Use case diagram

4.2.3 Class Diagram

Fig. 4.4 shows the main classes and modules. The pipeline aggregates the three working agents. The orchestrator depends on the evidence gate, the grounding verifier and the LLM service. Both the orchestrator and the optimizer reach the engine only through the Flask service, which keeps the agents independent of how metrics are computed.

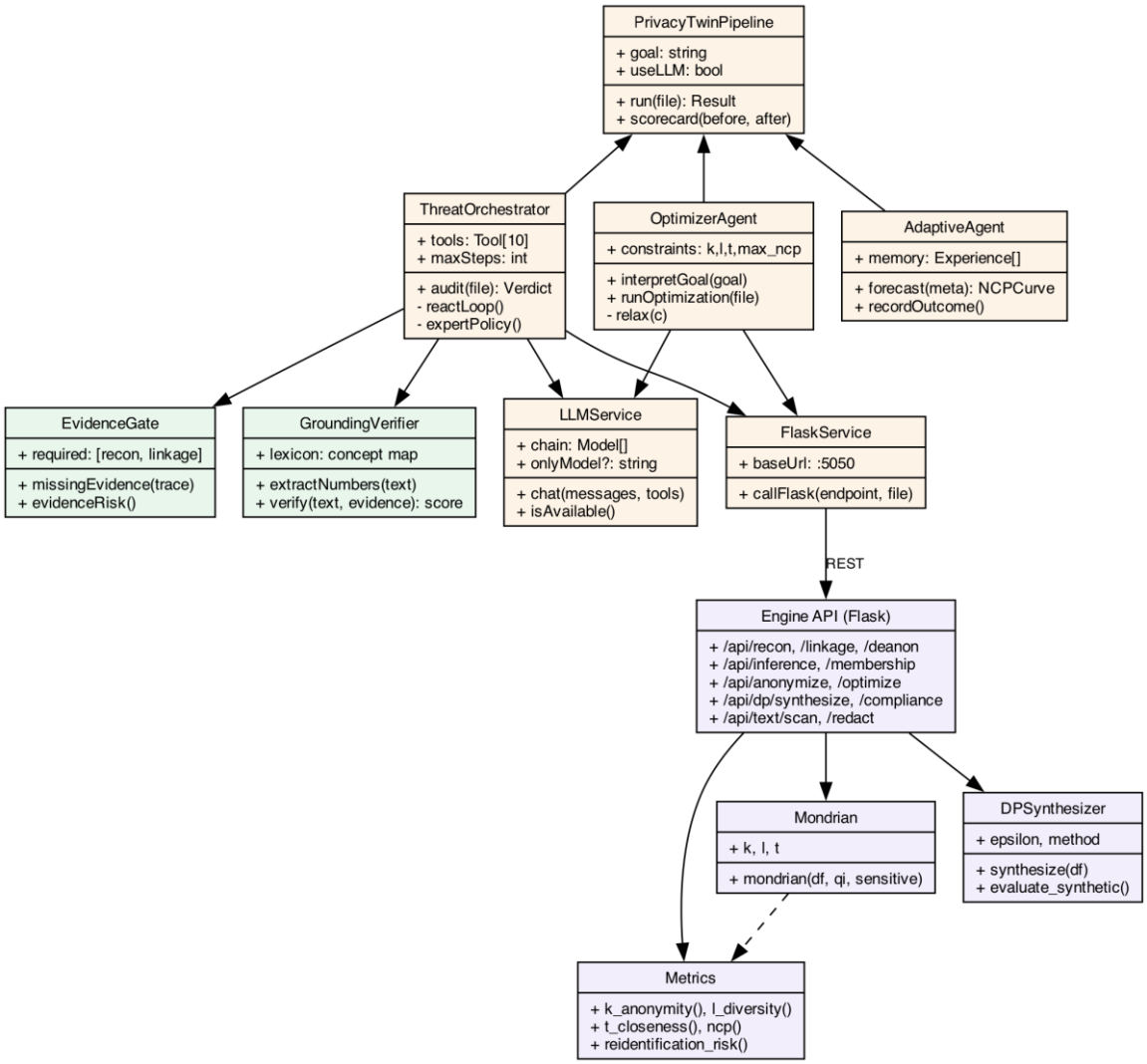


Fig. 4.4 Class diagram of the agent layer and engine

4.2.4 Sequence Diagram

Fig. 4.5 traces one Privacy Twin run. The gateway returns a job identifier at once and the browser polls for progress, so a long LLM run never blocks a request. Within the run, the evidence gate and the grounding verifier act before the verdict is passed on, and the optimizer re-attacks its own release before reporting.

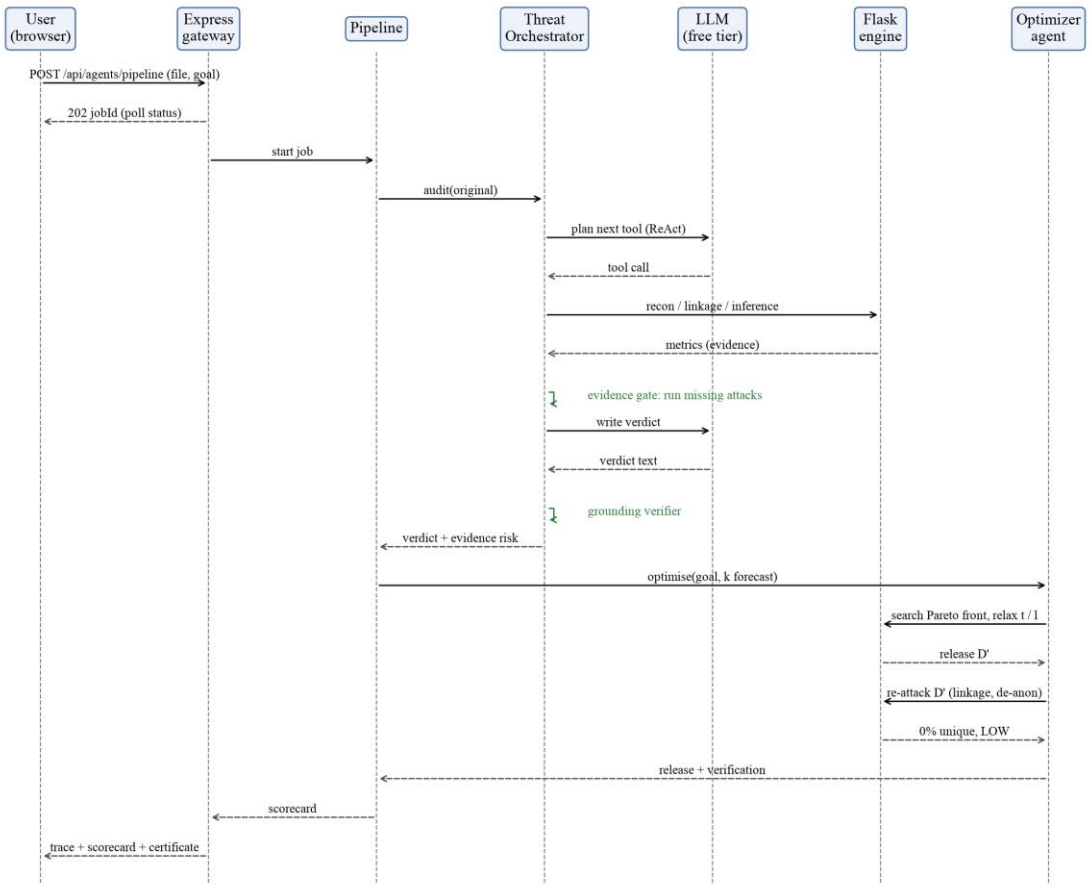


Fig. 4.5 Sequence diagram of a Privacy Twin run

CHAPTER 5

5. METHODOLOGY AND TESTING

5.1 Module Description

5.1.1 Ingestion and schema inference

The ingestion module reads every supported format into a pandas data frame (tables) or plain text (documents), rejects unsupported types and malformed files with a 400 error, and enforces the size limit. The schema module classifies columns as direct identifiers, quasi-identifiers, sensitive attributes or other, using names, value patterns and cardinality. Users can override the QIs and the sensitive attribute, and the research harness always does, so that results do not depend on heuristics.

5.1.2 Attack modules

- **Reconnaissance** computes equivalence classes over the QIs, sample uniqueness, the minimum class size *k*, the average and maximum prosecutor risk P_r = 1/|class| [26], and a composite Privacy Risk Index whose components are always displayed.
- **Linkage** measures the mean share of unique records when the attacker knows *m* randomly chosen QIs, for *m* = 1…|QI|, in the spirit of Rocher *et al.* [4], and simulates a join against an external table.
- **De-anonymisation** removes direct identifiers and, for sampled targets, searches with noisy background knowledge (±2 on numeric QIs). It reports the expected success E[1/|C|] over candidate sets C and the exact re-identification rate.
- **Attribute inference** trains a random forest to predict the sensitive attribute from the QIs and reports the normalised advantage $(a - a_0)/(1 - a_0)$ over the majority baseline a_0, so that a high accuracy on an imbalanced label is not mistaken for leakage.
- **Membership inference** trains a target model on disjoint member data, then runs a confidence-threshold attack [16] and a shadow-model attack [15], reporting ROC AUC and the true-positive rate at 1% false-positive rate [17].

5.1.3 Defence modules

- **Column fixes:** numeric and categorical generalisation hierarchies, masking, keyed HMAC pseudonyms that cannot be reversed by guessing, and suppression. Already-protected columns are detected and not processed twice.
- **Full-domain generalisation:** one hierarchy level (1–3) applied to every QI, followed by suppression of classes smaller than *k* [6].
- **Strict Mondrian:** recursive median cuts on the widest normalised dimension; a cut is allowed only if both halves remain *k*-anonymous, ℓ-diverse and *t*-close (ordered earth mover's distance for numeric attributes) [28], [9]. The code is listed in Appendix A.

- **Optimizer:** evaluates Mondrian and full-domain candidates over a grid of *k*, keeps the Pareto front of information loss versus residual risk, chooses the feasible point with the best utility, and verifies the release.

5.1.4 Differential privacy module

All synthesizers share one public discretisation of the columns, so that they are compared on equal terms. Independent marginals release a Laplace-noised histogram per column. PrivBayes (our implementation, degree 1) selects a Bayesian network with the exponential mechanism using mutual information and releases noisy conditional tables [12]. MST and AIM are called through OpenDP SmartNoise [38], [13], [14]. Each release is evaluated for fidelity (one- and two-way total variation distance, TVD), utility (train-on-synthetic, test-on-real accuracy, TSTR) and copying (the share of synthetic rows closer to a training record than to a holdout record, DCR; 0.5 means no copying).

5.1.5 Compliance and document PII

The compliance module maps columns to the 18 HIPAA Safe Harbor identifier categories [19], GDPR personal and special-category data [18] and DPDP Act 2023 indicators [20]. The document module finds names, e-mails, phone numbers, Aadhaar numbers (validated with the Verhoeff checksum [39]), PAN and payment-card numbers (Luhn check) in PDF, DOCX and TXT files and produces a redacted copy.

5.1.6 Agent layer

All agents run on **free-tier models only**: openai/gpt-oss-120b, openai/gpt-oss-20b and qwen/qwen3.8-27b on Groq, with Gemini as an optional extra. Tool observations are compacted to fit an 8k tokens-per-minute quota. The LLM service tries models in a chain, retries on the same model when the provider rejects a malformed tool call, and can be pinned to one model for experiments. When no key is configured, or every model fails, a deterministic expert policy completes the task, so every feature works offline.

- **Threat Orchestrator (red team).** A ReAct loop [34] over ten tools: profile, reconnaissance, linkage, de-anonymisation, inference, membership, compliance, defence analysis, apply defences and finish. It chases the worst risk it observes and must end with a structured verdict.
- **Evidence gate.** Before a verdict is accepted, the gate checks that reconnaissance and, when QIs exist, linkage were run, and runs them if not. It shows the evidence-derived release risk (the highest level across release attacks) beside the agent's rating.
- **Grounding verifier.** Extracts every number from agent text and requires a matching number in the agent's observations, within one unit of the last written digit and allowing percent/fraction conversion. It also binds each number to a metric: evidence values take a concept from their key (for example unique_records_pct → uniqueness), written numbers take concepts from the words around them in the same clause, and a claim is grounded only by a value with a matching concept. Thresholds such as "$k \geq 5$" and denominators such as "/100" are not treated as claims.

- **Optimization & Verification agent (blue team).** Maps a goal such as "share with a research partner who will train models" to constraints. A rule-based floor is computed first, and the LLM may tighten but never loosen it. If no configuration is feasible, it relaxes *t*, then ℓ, then the information-loss cap, and never *k*. It re-attacks its own release.
- **Adaptive agent.** Describes each dataset with meta-features (rows, QI count, cardinalities, uniqueness) and forecasts NCP(*k*) from the three nearest past datasets [40]. It recommends the largest *k* within an NCP budget, records the realised outcome, and reports its own hit rate.
- **Explainer.** Explains each attack in three plain-English points (what happened, why it is dangerous, real-world impact) and drafts a remediation plan; its numbers are checked by the same verifier.

5.2 Experimental Methodology

The research questions behind experiments E1–E7 are: how exposed typical releases are (RQ1); what k-anonymity costs (RQ2) and what it removes (RQ3); whether DP synthesis helps (RQ4); whether trained models leak membership (RQ5); whether the affordable k can be predicted (RQ6); and whether LLM agents can be trusted (RQ7).

Table 5.1 Benchmark datasets and attacker models (QIs: attributes the adversary is assumed to know)

Dataset	n	Quasi-identifiers	Sensitive
Adult [41], [42]	32,561	age, workclass, education, marital_status, occupation, race, gender, country	income
Heart [43], [44]	303	age, sex	target
German [45]	1,000	age, gender, marital_status, job, housing, foreign_worker	credit_risk
Bank [46], [47]	45,211	age, occupation, marital_status, education	subscribed
Diabetes [48], [49]	69,570	race, gender, age, admission_type_id, admission_source_id, time_in_hospital	readmitted

Protocol. We used 10 seeds for attack and membership experiments, 5 for anonymisation accuracy and PrivBayes, 3 for MST and 2 for AIM (AIM takes up to 170 s per fit, and MST/AIM noise comes from OpenDP's unseedable cryptographic random number generator). Models train on at most 20,000 rows with a 70/30 split. The QI set for Adult follows LeFevre et al. [28]; Heart's label is binarised; Diabetes keeps the first encounter per patient.

Statistics. Paired comparisons use the Wilcoxon signed-rank test [50] with bootstrap 95% confidence intervals, and every family of tests is Holm-corrected [51]. Rankings over (dataset, k) blocks use the Friedman test [52] with the Nemenyi critical difference [53]. Paired hit/miss outcomes use the exact McNemar test [54], and proportions carry Wilson intervals [55].

Agent study. For each of six datasets (the five benchmarks plus a synthetic table with names, e-mails and phone numbers) we ran one audit with the expert policy and two with each free model, 42 audits in all, on 13 October 2026. Each LLM audit was pinned to one model with

no fallback, so we could tell whether a model finished apart from whether it was right. To test the grounding verifier, we planted faults in finished verdicts: random wrong values, and swaps in which a number is replaced by the true value of a different metric. The metric vocabulary was built on the main study and tested unchanged on an earlier pilot.

5.3 Testing

Testing was done at three levels: unit tests of each algorithm against small worked examples, API tests of every route including error paths, and end-to-end runs through the browser. All suites run with one command (scripts/test.sh) and in a GitHub Actions workflow on every push.

Table 5.2 Automated test suites

Tier	Framework	Tests	Coverage focus
Privacy engine	pytest	59	Metrics (k, ℓ, t, NCP), Mondrian invariants, attacks, DP synthesis, compliance, document PII, every API route and error path, all upload formats
Gateway and agents	Jest + Supertest	77	Routes, job queue, LLM fallback and retry, evidence gate, grounding verifier, optimizer negotiation, adaptive forecasting, pipeline
Frontend	React Testing Library	17	Pages render, API client, agent trace and result panels, research page regression
Total		153	Plus a production build of the frontend in CI

Table 5.3 Representative test cases

ID	Test case	Expected result	Status
T1	Mondrian with k = 5, ℓ = 2, t = 0.4 on a sample table	Every class has ≥ 5 records, ≥ 2 sensitive values and EMD ≤ 0.4	Pass
T2	Upload a .exe file	HTTP 400, no crash	Pass
T3	Upload a malformed CSV	HTTP 400 with a readable message	Pass
T4	Upload XLSX, XLS and JSON versions of the same table	Same record count as the CSV	Pass
T5	Run a tabular attack on a TXT document	HTTP 400 (client error), not 500	Pass
T6	Defence: mask the e-mail column	Risk score after ≤ risk score before	Pass
T7	Agent verdict omits reconnaissance	Evidence gate runs recon and linkage before accepting	Pass
T8	Agent text swaps the uniqueness value into a risk-score claim	Verifier flags the number as misattributed	Pass
T9	Optimizer constraints infeasible until the NCP cap is dropped	Relaxes t to 0.6, ℓ to 1, then drops the cap; k unchanged; release re-attacked	Pass
T10	LLM provider returns a malformed tool name	Retry on the same model, then policy fallback	Pass
T11	Text scan of "jane@corp.com, +1 415 555 0134"	One e-mail and one phone detected and redacted	Pass
T12	Research manifest with seeds as a string	Page renders without crashing	Pass

End-to-end testing exposed several defects that unit tests had missed, and each was fixed with a regression test. Examples: the engine port clashed with a macOS system service (moved to 5050); legacy .xls files failed without the xlrd reader; the research page crashed when the seed list was stored as a string; and, while this report was being prepared, a live Privacy Twin run showed that the optimizer's negotiation loop stopped after five rounds, before it could relax ℓ or the information-loss cap. The cap was raised so that every relaxation can be tried, and test T9 now covers that case.

CHAPTER 6

6. PROJECT DEMONSTRATION

This chapter walks through the application on the synthetic demonstration table research/data/synthetic_people.csv (2,000 generated people with names, e-mails, phone numbers, age, ZIP code, gender, education, occupation and income; no real persons). The servers are started with one command, ./scripts/dev.sh, and the interface opens at http://localhost:3000.

6.1 Dashboard

The dashboard (Fig. 6.1) shows the engine and LLM status, the number of datasets analysed, agent runs, reports and the adaptive agent's hit rate, together with recent agent runs and an audit trail of every action.

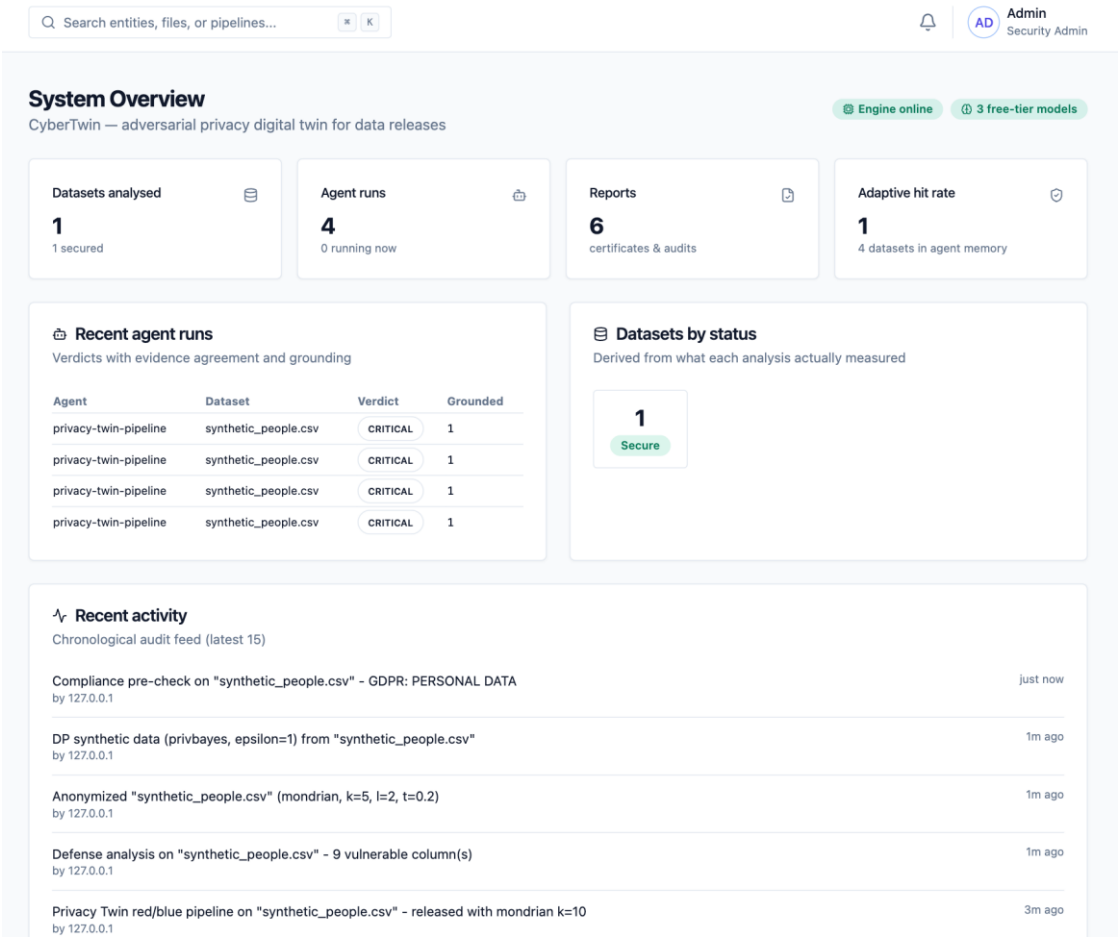


Fig. 6.1 Dashboard with system status, recent agent runs and activity log

6.2 Attack Lab

The user uploads the table once, optionally names the attacker's QIs and the sensitive attribute, selects attacks and presses Launch Attacks. A live feed reports each step (Fig. 6.2). The results (Fig. 6.3) show a score per attack, the attack surface, the uniqueness curve as the attacker

learns more QIs, de-anonymisation success and the membership-inference ROC curve. On this table 94.4% of the 2,000 records are unique on the QIs, so reconnaissance and linkage are critical.

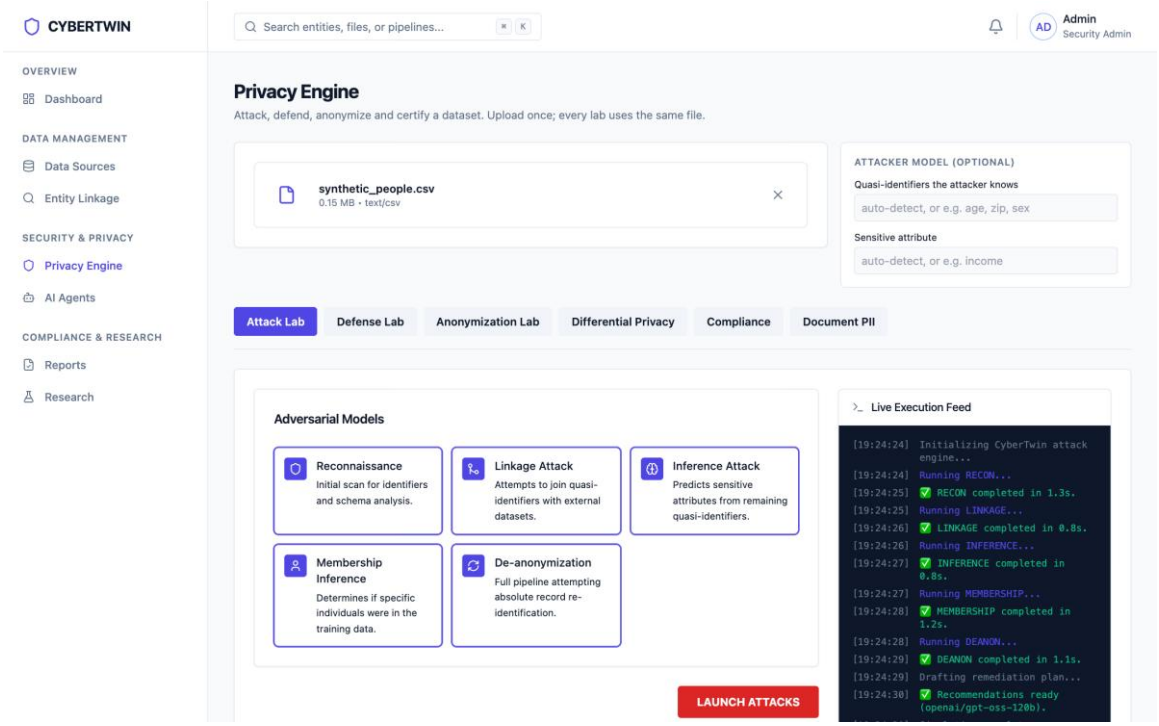


Fig. 6.2 Privacy Engine with the file uploaded and attacks selected



Fig. 6.3 Attack results: scores, attack surface, uniqueness, de-anonymisation and ROC curves

Below the charts, the Explainer agent explains each attack in plain English and drafts a remediation plan (Fig. 6.4). Each card shows which free model wrote it and how many of its numbers were grounded in the engine output.

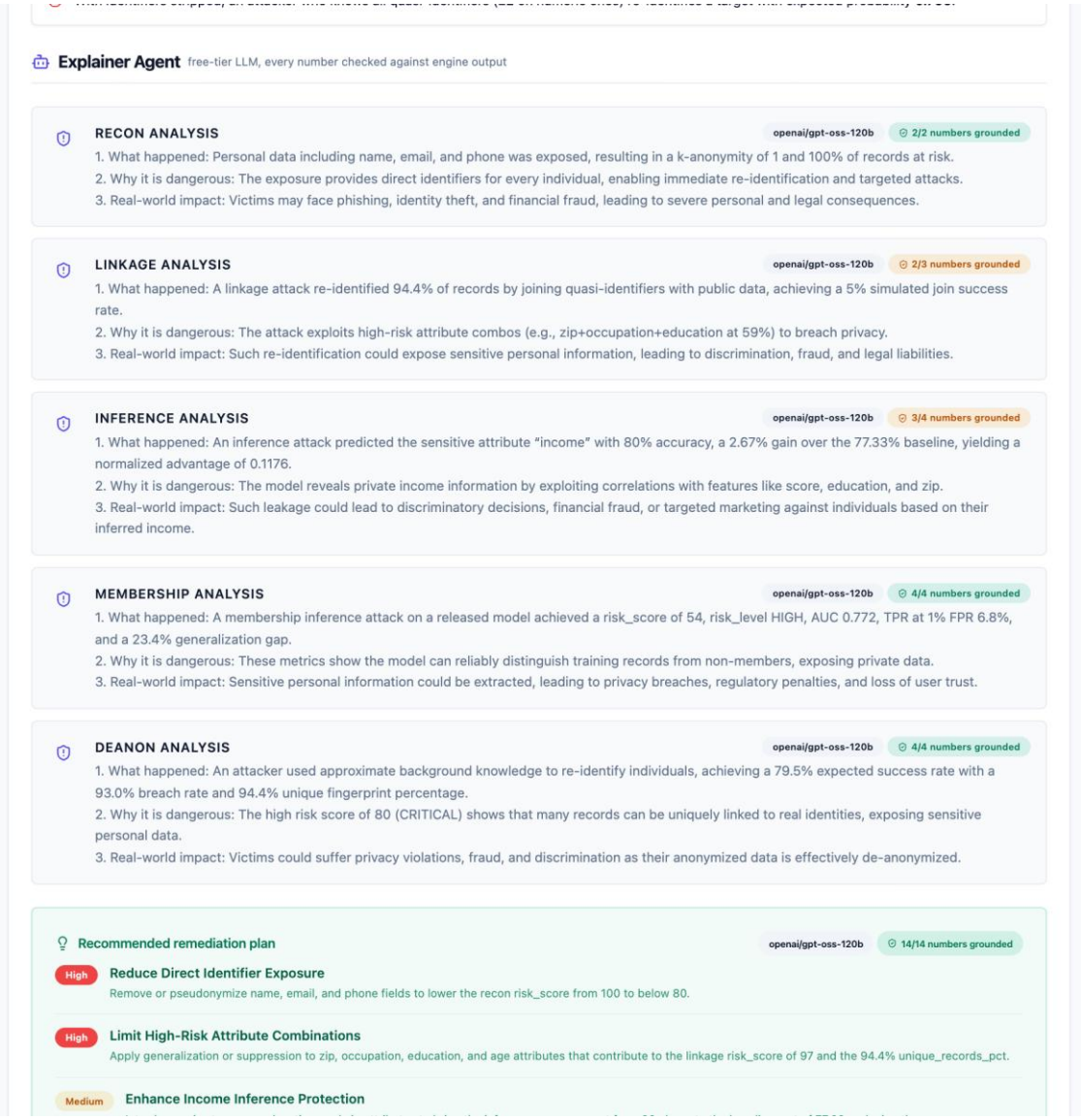


Fig. 6.4 Explainer agent output with per-card grounding badges

6.3 Defense, Anonymization, Differential Privacy and Compliance Labs

The Defense Lab scans the columns and proposes a fix for each risky one (Fig. 6.5). The Anonymization Lab applies Mondrian or full-domain k-anonymity with ℓ and t and shows record retention and information loss (Fig. 6.6). The Differential Privacy lab generates ε-DP synthetic data and reports fidelity, utility and copying (Fig. 6.7). The Compliance lab runs the HIPAA, GDPR and DPDP pre-checks (Fig. 6.8).

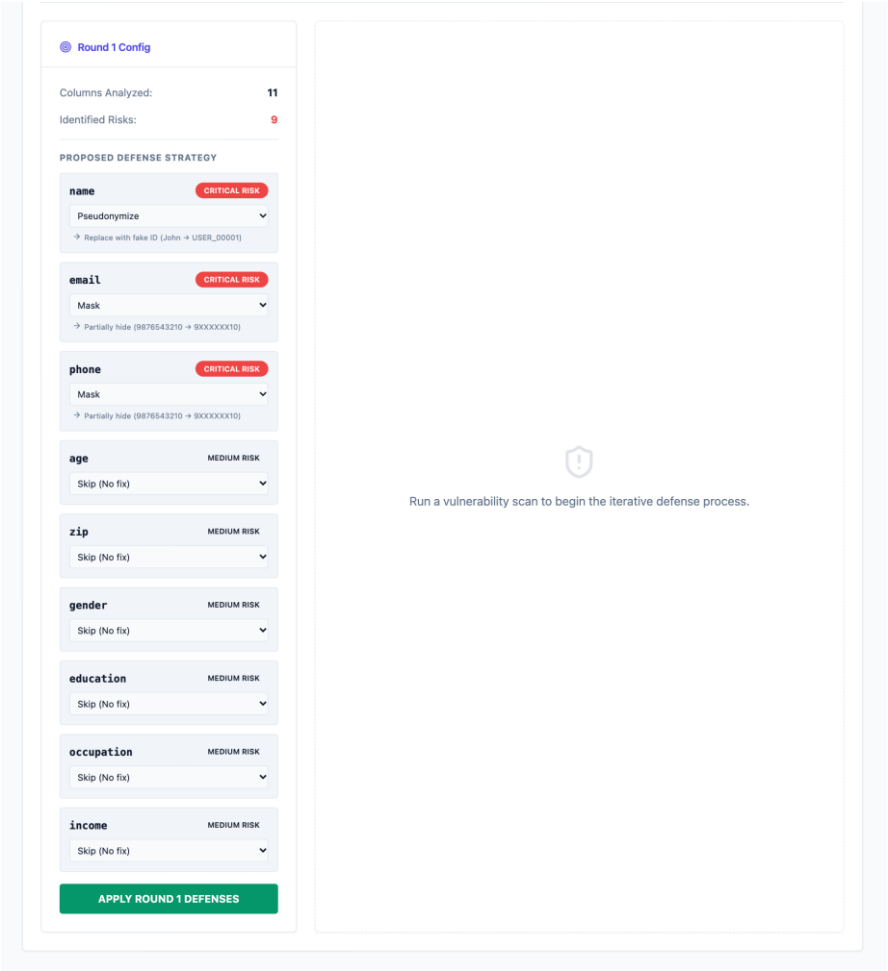


Fig. 6.5 Defense Lab: proposed fix per column

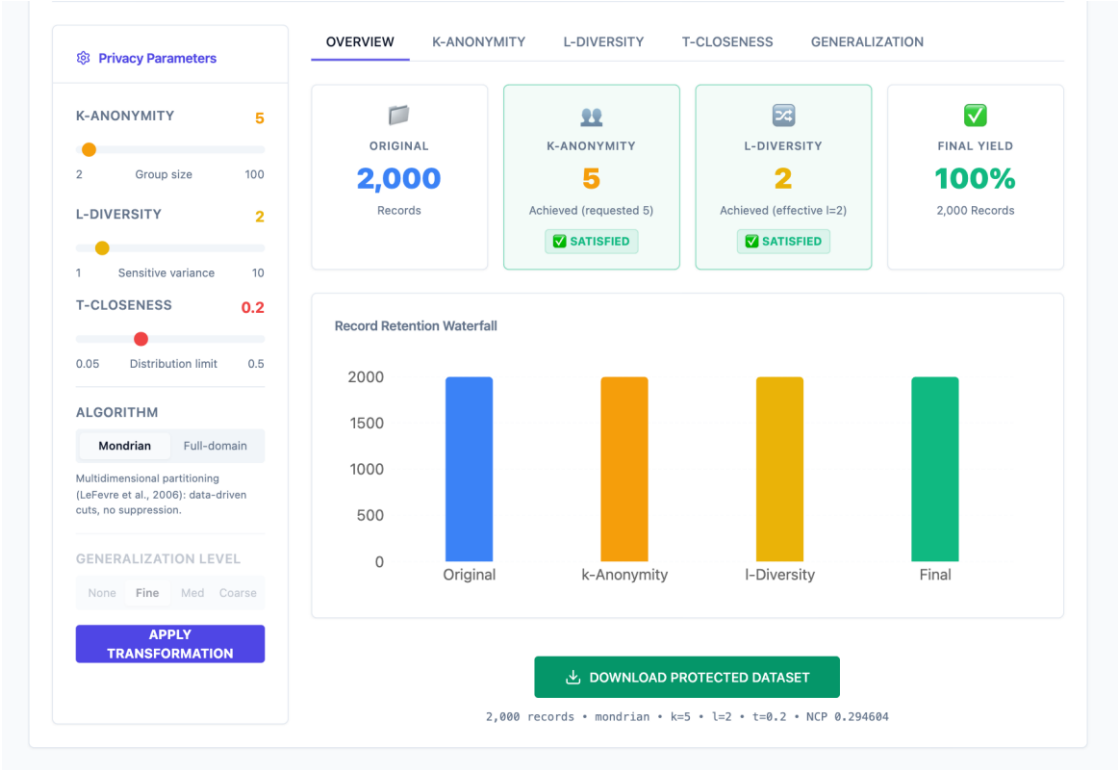


Fig. 6.6 Anonymization Lab: Mondrian with k = 5, ℓ = 2, t = 0.2, all 2,000 records kept

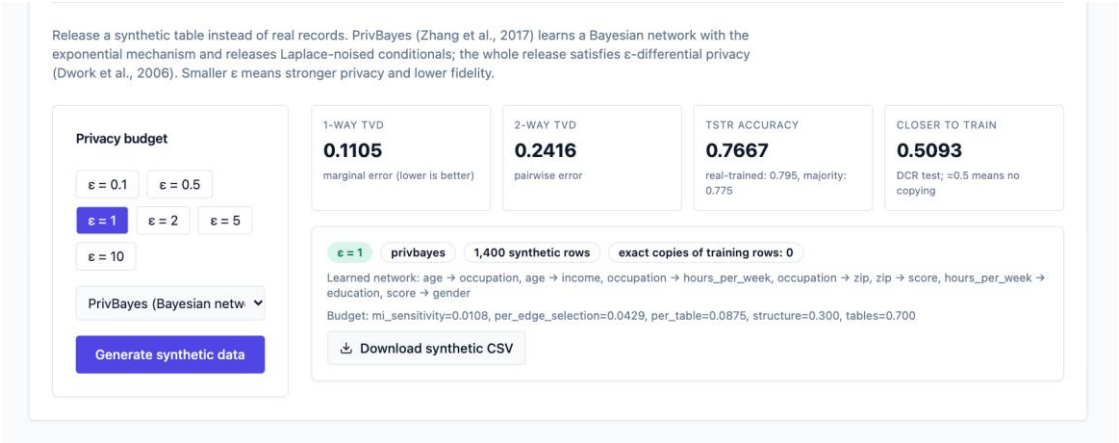


Fig. 6.7 Differential Privacy lab: PrivBayes at ε = 1 with fidelity, TSTR accuracy and DCR

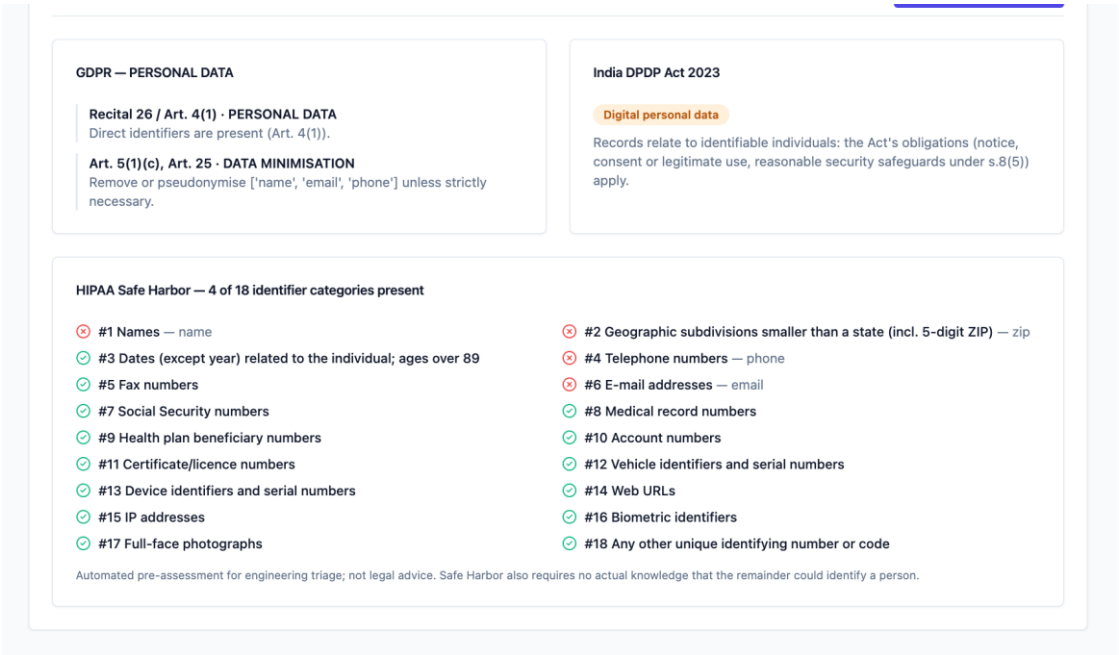


Fig. 6.8 Compliance pre-assessment: HIPAA Safe Harbor, GDPR and DPDP Act 2023

6.4 AI Agents: the Privacy Twin Loop

On the AI Agents page the user chooses Privacy Twin (red → blue → red), uploads the table, types a goal such as "Share with an external research partner who will train income-prediction models; keep utility high" and presses Run. The live reasoning trace (Fig. 6.9) shows each step, the model that took it, its thought and the tool output it observed.



Fig. 6.9 Live reasoning trace of the red-team agent (gpt-oss-120b, free tier)

The scorecard (Fig. 6.10) compares the same attacks before and after protection. Unique records fall from 94.4% to 0%, k rises from 1 to 10, the maximum prosecutor risk falls from 1 to 0.1, and de-anonymisation success falls from 0.795 to 0.072, at an information cost of NCP 0.19 with every record kept.

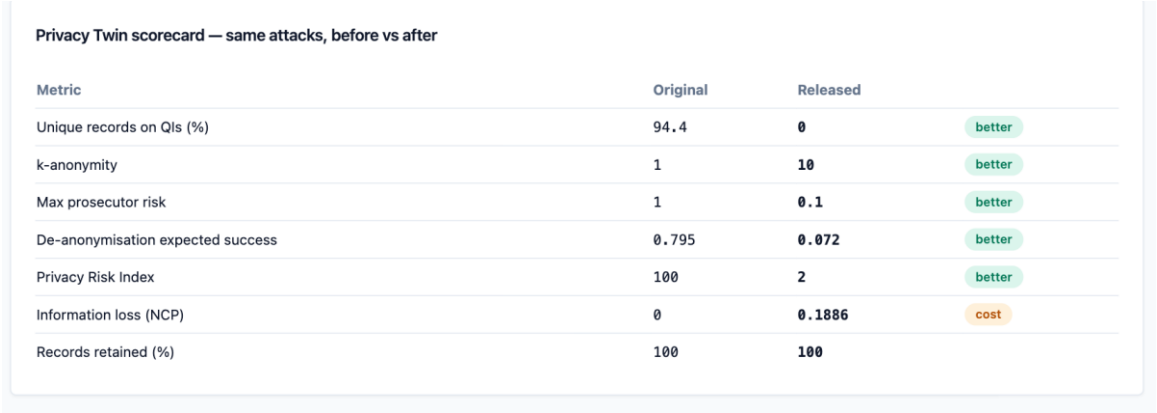


Fig. 6.10 Privacy Twin scorecard: the same attacks on the original and on the released table

The Threat Orchestrator's verdict (Fig. 6.11) carries the evidence check: the release risk derived from the attack outputs is shown beside the model's own rating, and a badge reports that 7 of 7 numbers in the verdict were grounded. The Optimization & Verification agent (Fig. 6.12) shows the constraints it negotiated ($k \geq 10$ kept, t and ℓ relaxed), the Pareto front, the chosen Mondrian release and the verification re-attack, with 19 of 19 numbers grounded.

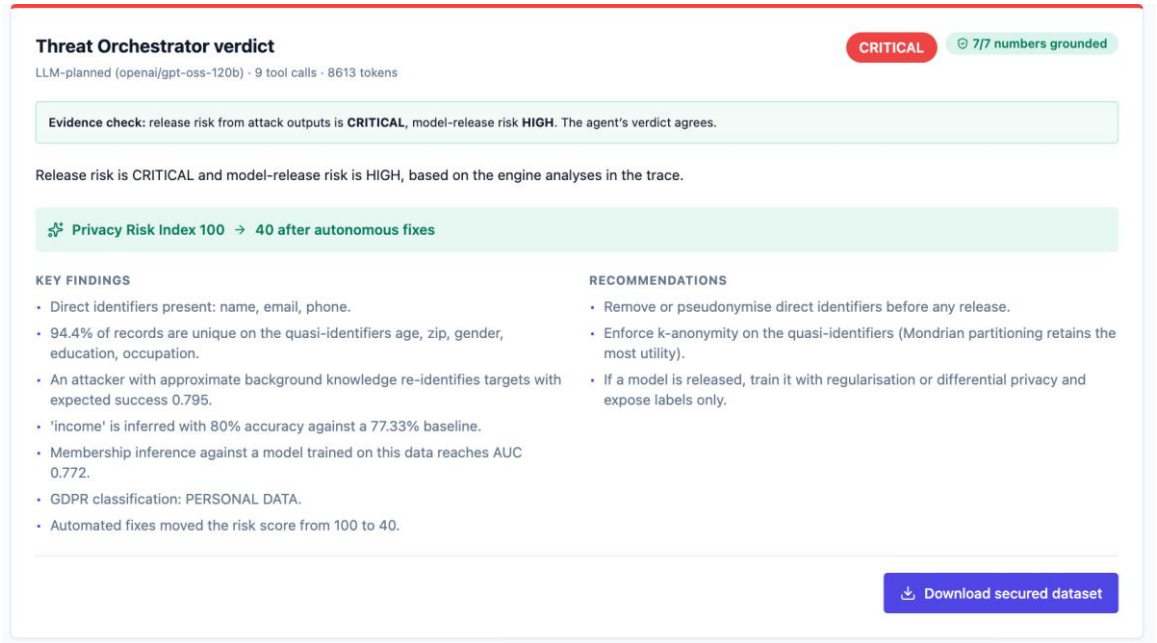


Fig. 6.11 Threat Orchestrator verdict with evidence check and grounding badge



Fig. 6.12 Optimization & Verification agent: negotiated constraints, Pareto front and re-attack

6.5 Research Page

The Research page (Fig. 6.13) renders the experiment manifest, figures, tables and findings directly from the results directory, so the website always shows the numbers in the papers.

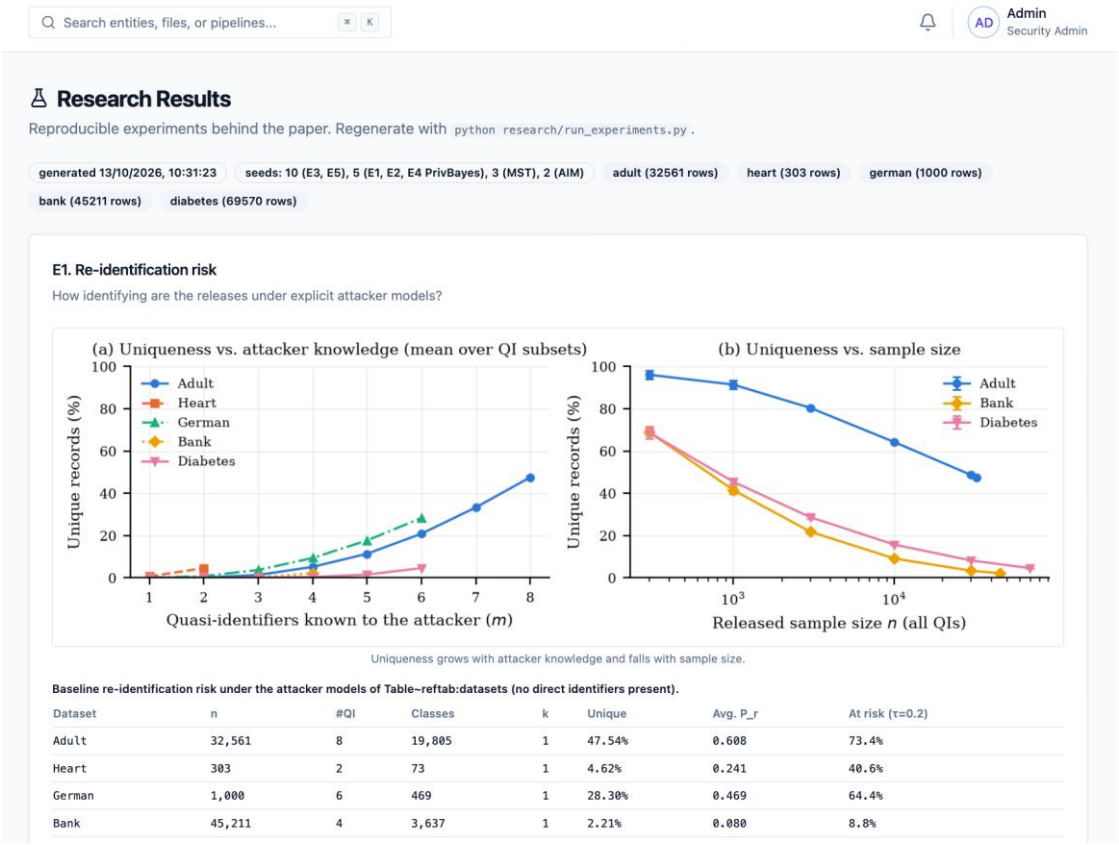


Fig. 6.13 Research page showing experiment E1

CHAPTER 7

7. RESULT AND DISCUSSION

7.1 Experimental Results

7.1.1 RQ1: How exposed are the releases?

All five datasets have k = 1, so at least one record is unique in each (Table 7.1). The share of unique records ranges from 2.2% on Bank to 47.5% on Adult, and German Credit is close behind at 28.3%. Fig. 7.1(b) shows a result that surprised us: smaller samples are riskier. Releasing only 300 rows makes 96.1% of Adult records unique and 68.9% of Bank records, so releasing "just a sample" makes things worse, not better.

Table 7.1 Baseline re-identification risk under the stated attacker models

Dataset	n	QIs	Classes	k	Unique	Avg. P_r	At risk (τ = 0.2)
Adult	32,561	8	19,805	1	47.54%	0.608	73.4%
Heart	303	2	73	1	4.62%	0.241	40.6%
German	1,000	6	469	1	28.30%	0.469	64.4%
Bank	45,211	4	3,637	1	2.21%	0.080	8.8%
Diabetes	69,570	6	7,255	1	4.61%	0.104	12.5%

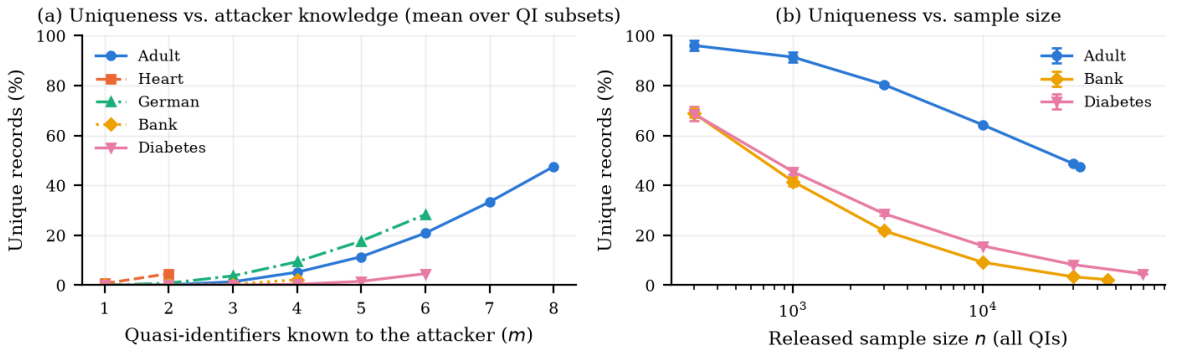


Fig. 7.1 (a) Unique records as the attacker learns more QIs; (b) smaller samples are more identifying

7.1.2 RQ2: What does k-anonymity cost?

Mondrian came first on both information loss (mean rank 1.07; Friedman $\chi^2 = 51.9$, $p = 3\times10^{-11}$) and downstream accuracy (mean rank 1.48; $\chi^2 = 25.0$, $p = 2\times10^{-5}$), and its lead over every full-domain level exceeds the Nemenyi critical difference (Fig. 7.2, Fig. 7.3). Across the 30 (dataset, k) blocks it cut NCP by 0.18–0.25 and added 1.0–1.2 accuracy points against each full-domain level, with every Holm-corrected p below 0.001 (Table 7.2). At k = 10 Mondrian costs between 0.007 and 0.145 NCP and drops no records, while the best full-domain level costs 0.05–0.31 and discards up to 52% of Adult.

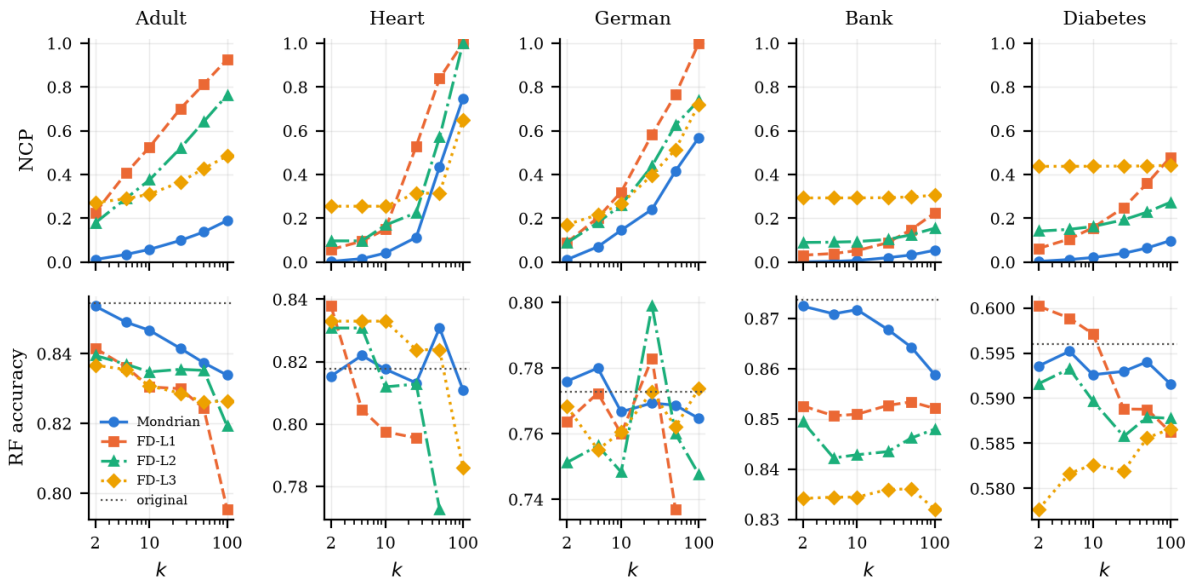


Fig. 7.2 NCP and downstream random-forest accuracy versus k (accuracy averaged over 5 seeds)

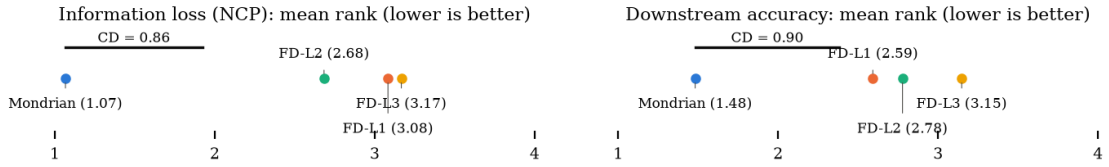


Fig. 7.3 Mean Friedman ranks over 30 (dataset, k) blocks with the Nemenyi critical difference (CD)

Table 7.2 Mondrian versus full-domain (FD) generalisation: paired Wilcoxon tests, Holm-corrected

Comparison	Mean diff.	95% CI	r	p (Holm)
NCP: Mondrian vs FD-L1	−0.251	[−0.322, −0.184]	−1.00	< 0.001
Acc.: Mondrian vs FD-L1	+0.010	[+0.005, +0.015]	+0.73	< 0.001
NCP: Mondrian vs FD-L2	−0.179	[−0.226, −0.139]	−1.00	< 0.001
Acc.: Mondrian vs FD-L2	+0.011	[+0.005, +0.017]	+0.73	< 0.001
NCP: Mondrian vs FD-L3	−0.240	[−0.283, −0.192]	−0.97	< 0.001
Acc.: Mondrian vs FD-L3	+0.012	[+0.006, +0.017]	+0.69	< 0.001

7.1.3 RQ3: What does the defence actually remove?

Linkage risk disappears: every k-anonymous release has no unique records and a maximum prosecutor risk of 1/k. Attribute inference is a different story (Table 7.3). It is meaningful on only three datasets, because on Bank and Diabetes the attacker never beats the majority guess. On those three, Mondrian at k = 10 lowered the attacker's advantage only on Adult, from 0.40 to 0.37 (p_Holm = 0.02); adding $\ell = 2$ and t = 0.2 brought it to 0.30. On Heart and German nothing changed. Inference from population-wide correlations was never part of what k-anonymity promises, and a report that showed only k would hide it.

Table 7.3 Summary across the five benchmarks (* differs from original or still > 0.5, Holm p < 0.05)

Data	Uniq.	NCP Mond.	NCP FD	Inf. orig.	k = 10	+ℓ, t	MIA RF	MIA reg.
Adult	47.5%	0.058	0.310	+0.40	+0.37*	+0.30*	0.64	0.50
Heart	4.6%	0.041	0.149	+0.62	+0.62	+0.62	0.75	0.51
German	28.3%	0.145	0.260	+0.22	+0.22	+0.21	0.80	0.52
Bank	2.2%	0.007	0.052	−0.09	−0.10	−0.14*	0.70	0.53*
Diabetes	4.6%	0.021	0.157	−0.00	−0.01	−0.01*	0.94	0.59*

7.1.4 RQ4: Does DP synthesis help?

At $\varepsilon \leq 1$, plain independent marginals reproduced pairs of attributes significantly better than both PrivBayes and MST (Holm $p \leq 0.013$; Fig. 7.4). The tree-based models split their budget over larger tables, and on most attribute pairs the extra noise costs more than the captured dependence is worth. At $\varepsilon = 10$ PrivBayes and independent marginals were level, while MST was significantly worse (+0.06 TVD, $p = 0.001$). None of the synthesizers made models trained on synthetic data significantly more accurate than always predicting the majority class; only AIM, which models higher-order marginals, beat it on Adult (+1.9 points at $\varepsilon = 1$). The DCR share stayed near 0.5 throughout, so we saw no sign of copied records.

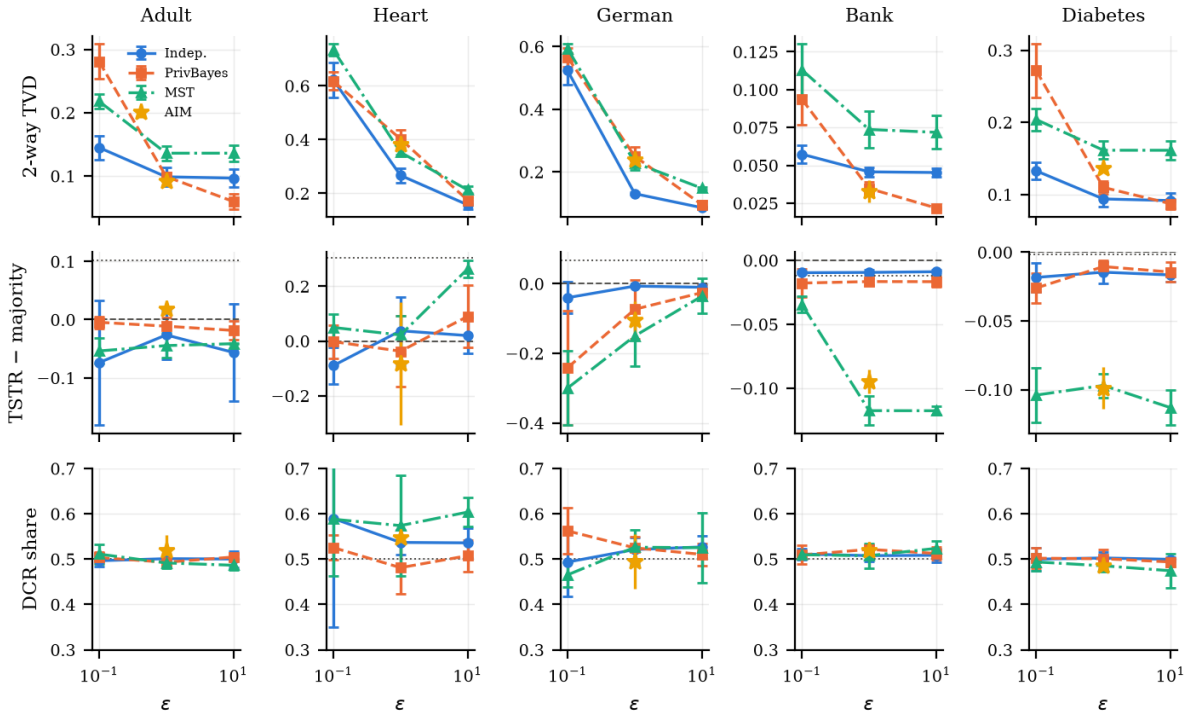


Fig. 7.4 DP synthesis versus ε: two-way TVD, TSTR gain over the majority class, and DCR share

7.1.5 RQ5: Do trained models leak membership?

A random forest with default settings leaked membership on all five datasets (shadow AUC 0.64–0.94; Fig. 7.5, Table 7.4). Diabetes was the worst case, with 24.8% of members identified at a 1% false-positive rate. Requiring 20 samples per leaf lowered AUC significantly everywhere and cost at most 5 accuracy points, but Bank (0.53) and Diabetes

(0.59) still leaked. Models trained on PrivBayes data sat at chance (0.50), although on Heart they lost up to 27 accuracy points.

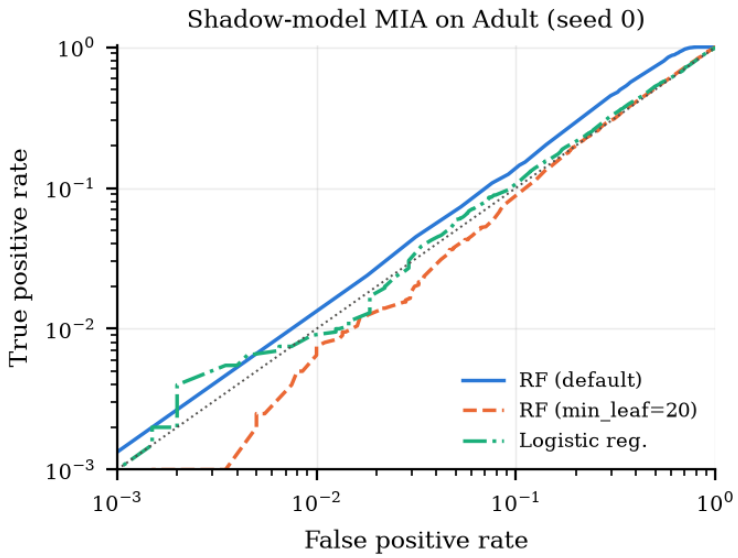


Fig. 7.5 Membership-inference ROC curves for default and regularised random forests

Table 7.4 Membership inference (10 seeds): shadow-model AUC, TPR at 1% FPR and test accuracy

Data	Target model	AUC shadow	TPR@1%	Test acc.	p (Holm)
Adult	RF (default)	0.643	0.5%	0.845	0.024
Adult	RF (min_leaf = 20)	0.503	1.2%	0.841	1.000
Heart	RF (default)	0.746	2.1%	0.804	0.024
Heart	RF (min_leaf = 20)	0.513	0.5%	0.752	1.000
German	RF (default)	0.799	2.0%	0.726	0.024
German	RF (min_leaf = 20)	0.524	1.0%	0.694	0.164
Bank	RF (default)	0.695	0.2%	0.872	0.024
Bank	RF (min_leaf = 20)	0.529	1.2%	0.883	0.024
Diabetes	RF (default)	0.938	24.8%	0.587	0.024
Diabetes	RF (min_leaf = 20)	0.587	2.5%	0.603	0.024

7.1.6 RQ6: Can we predict the affordable k?

We built 60 tasks from the five datasets by sampling QI subsets and sample sizes, and tested leave-one-dataset-out with an NCP budget of 0.3 (Table 7.5, Fig. 7.6). The forecaster picked the exact affordable k in 63% of tasks and was within one step in 98%. That is far better than a fixed k = 5 (2%, McNemar $p < 0.001$), and it chose an unaffordable k much less often than a global-average curve (17% against 45%). It was not, however, significantly more accurate than that average ($p = 0.41$). Because it reaches 81% on synthetic tasks, the difficulty lies in transferring from synthetic to real data. We report this as a negative result.

Table 7.5 Forecasting the largest affordable k on 60 real-derived tasks (leave-one-dataset-out)

Strategy	Exact (95% CI)	±1 step	Violation
Fixed k = 5	2% [0, 9]	12%	0%
Random k	33% [23, 46]	52%	7%
Global mean curve	55% [42, 67]	88%	45%
k-NN forecast (ours)	63% [51, 74]	98%	17%

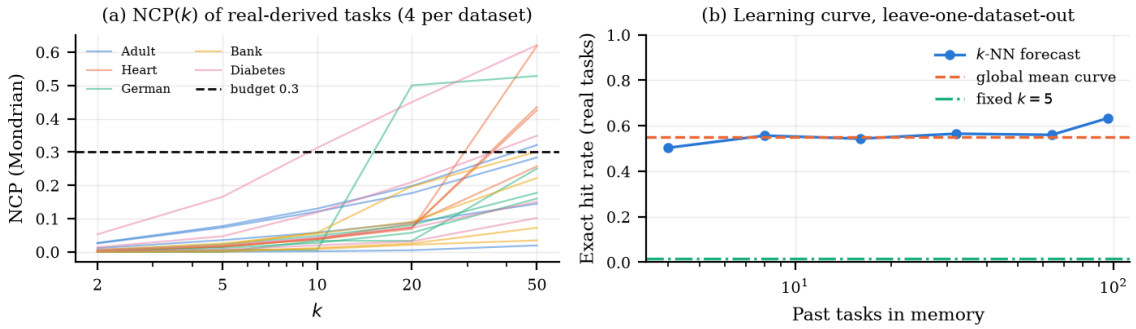


Fig. 7.6 Adaptive forecaster: accuracy of the recommended k

7.1.7 RQ7: Can we trust the agents?

The models differ a lot in reliability (Table 7.6, Fig. 7.7). qwen3.8-27b finished 11 of 12 audits on its own, gpt-oss-120b 9 and gpt-oss-20b only 4 (χ^2 p = 0.008). When we reproduced a failure, the cause was a broken tool call: chat-format tokens leaked into the tool name and the provider rejected it. The policy fallback finished every abandoned audit, so the system as a whole gave the correct verdict in 34 of 36 audits.

Finished audits are usually right, and when they are wrong it is in one direction. The verdict matched the evidence in 22 of 24 finished audits (92%, CI [74, 98]). Both errors came from gpt-oss-120b and both understated the risk (HIGH reported as LOW on Heart, MEDIUM as LOW on Diabetes). In both runs the agent had skipped reconnaissance and the evidence gate had to run it; none of the runs without a gate intervention went wrong (Fisher p = 0.022). Skipped evidence is therefore a warning sign an operator can watch for.

Table 7.6 Threat Orchestrator audits on six datasets, each LLM run pinned to one free-tier model

Arm	Completed	Agreement	Under/over	Gate	Grounded	Tokens
Expert policy	–	100% [61, 100]	0/0	0/6	32/32	0
gpt-oss-120b	9/12	78% [45, 94]	2/0	3/9	66/69	8,306
gpt-oss-20b	4/12	100% [51, 100]	0/0	1/4	23/23	9,834
qwen3.8-27b	11/12	100% [74, 100]	0/0	0/11	245/252	12,375
All completed LLM	24/36	92% [74, 98]	2/0	4/24	334/344	10,426

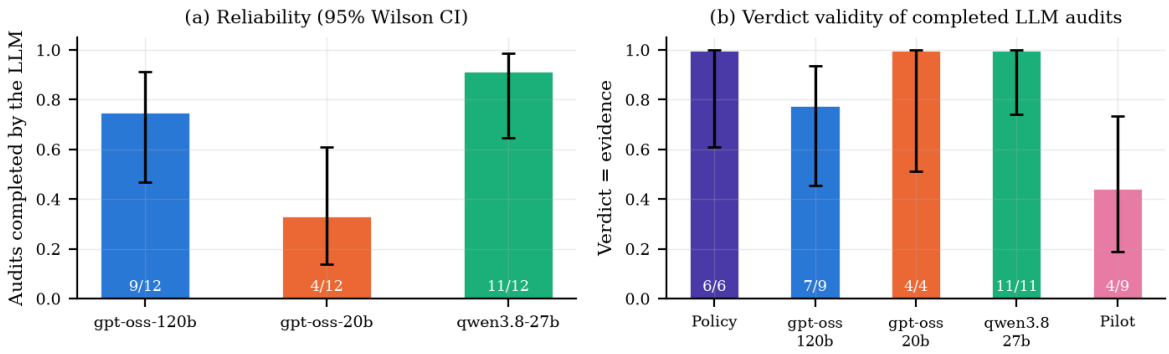


Fig. 7.7 (a) Audits each pinned free-tier model completed; (b) verdict agreement with evidence (95% Wilson CIs)

Binding numbers to metrics makes the fact check much stronger (Table 7.7). On held-out pilot traces, the attribute-bound verifier caught 96.5% of random fake numbers against 92.2% for value matching alone. The larger gain is on swapped numbers, where a claim borrows the true value of a different metric: 70.9% against 0.7%. Every discordant fault favoured the new check (McNemar $p = 0.031$ and $p < 0.001$); it raised no false alarms on correct text and accepted all 152 genuine LLM-written numbers.

Table 7.7 Grounding verifier: value-only versus attribute-bound matching on identical planted faults

Traces	Checker	Random recall	Swap recall	False alarms	Genuine
Main study (dev.)	Value-only	84.4%	0.5%	0/50	339/339
Main study (dev.)	Attribute-bound	96.8%	73.8%	0/50	406/406
Pilot (held out)	Value-only	92.2%	0.7%	0/27	125/125
Pilot (held out)	Attribute-bound	96.5%	70.9%	0/27	152/152

7.2 Discussion

Three lessons stand out. First, **a release has to be attacked again after it is protected.** k-anonymity removed linkage risk completely, yet it left attribute inference and membership leakage almost untouched, which a report showing only k would never reveal. Second, **for tables like these and a moderate ε, independent noisy marginals are a baseline that tree-based synthesizers do not reliably beat**, so practitioners should always compare against it. Third, **free-tier LLMs can serve as auditors, but only with guard rails.** Their reliability varied threefold between models, and their remaining errors were understatements that followed skipped evidence, which is exactly the failure the evidence gate is designed to catch.

Limitations. Five tabular datasets say nothing about longitudinal, graph or free-text data. Our QI choices are explicit, but others could reasonably choose differently. AIM ran only twice per setting. The agent study used one provider on one day, and hosted models change over time, which is why the harness and raw traces are published. The verifier's metric vocabulary is hand-built, and swapped numbers still escape it about 30% of the time. The compliance checks are triage aids, not legal advice.

7.3 Cost Analysis

The project was designed to run at zero recurring cost. Table 7.8 lists the cost items. Token counts come from the agent study: an LLM audit used about 10,400 tokens on average, and the free tiers allowed all 42 study audits, and all development runs, at no charge. Because the expert policy needs no LLM, the tool also has no hard dependency on any paid service.

Table 7.8 Cost analysis

Item	Details	Cost
Software licences	All dependencies open source (Python, Node.js, React, scikit-learn, OpenDP SmartNoise)	₹0
LLM inference	Groq free tier (gpt-oss-120b, gpt-oss-20b, qwen3.8-27b); ≈10.4k tokens per audit; expert policy offline	₹0
Datasets	UCI Machine Learning Repository, CC BY 4.0; generated synthetic table	₹0
Hardware	Team laptops; no GPU required	Existing
Experiments	E1–E7 on a laptop (≈75 minutes) plus the live agent study	₹0
Paper typesetting	LaTeX via Tectonic	₹0
Deployment (optional)	Any small Linux server or VM with Python and Node.js; cost depends on provider	Provider-dependent

CHAPTER 8

8. CONCLUSION

CyberTwin turns a pre-release privacy review into something that can be measured: attack, protect, attack again and compare. It combines five attacks, three families of defences, DP synthesis, compliance triage and document redaction in one web application, and lets free-tier LLM agents drive the loop under two safeguards, an evidence gate and an attribute-bound grounding verifier.

On five public datasets with stated attacker models and corrected statistics, every dataset was re-identifiable, Mondrian was the better route to k-anonymity, k-anonymity on its own did not stop attribute inference, regularisation reduced but did not always remove membership leakage, and simple DP marginals were hard to beat. The free LLM agents wrote accurate numbers and were usually right when they finished, but they often failed to finish, and when they skipped evidence they understated the risk. The evidence gate and the grounding verifier are what make them safe to use. Our forecaster for the affordable k beat a fixed default but not a simple average on unseen real data, and we report that honestly.

The work produced an open-source tool with 153 automated tests, an IEEE-format conference paper and an Elsevier-format journal paper.

Future work. (1) A larger agent study across more free providers (for example Gemini) and repeated days, to measure drift. (2) Learning the verifier's metric vocabulary instead of hand-building it, to close the remaining 30% of swapped numbers. (3) Better transfer of the k forecaster from synthetic to real data, for example by meta-learning on more public tables. (4) Support for longitudinal and free-text data, OCR for scanned PDFs, multi-sheet Excel and user authentication for multi-team deployment.

CHAPTER 9

9. REFERENCES

1. Sweeney, L., 2000. Simple demographics often identify people uniquely. *Carnegie Mellon University, Data Privacy Working Paper*, 3.
2. Golle, P., 2006. Revisiting the uniqueness of simple demographics in the US population. *Proceedings of the 5th ACM Workshop on Privacy in Electronic Society (WPES)*, pp. 77–80. doi: 10.1145/1179601.1179615.
3. Narayanan, A. and Shmatikov, V., 2008. Robust de-anonymization of large sparse datasets. *Proceedings of the IEEE Symposium on Security and Privacy*, pp. 111–125. doi: 10.1109/SP.2008.33.
4. Rocher, L., Hendrickx, J.M. and de Montjoye, Y.-A., 2019. Estimating the success of re-identifications in incomplete datasets using generative models. *Nature Communications*, 10(1), p. 3069. doi: 10.1038/s41467-019-10933-3.
5. El Emam, K., Jonker, E., Arbuckle, L. and Malin, B., 2011. A systematic review of re-identification attacks on health data. *PLoS ONE*, 6(12), p. e28071. doi: 10.1371/journal.pone.0028071.
6. Samarati, P., 2001. Protecting respondents' identities in microdata release. *IEEE Transactions on Knowledge and Data Engineering*, 13(6), pp. 1010–1027. doi: 10.1109/69.971193.
7. Sweeney, L., 2002. k-Anonymity: A model for protecting privacy. *International Journal of Uncertainty, Fuzziness and Knowledge-Based Systems*, 10(5), pp. 557–570. doi: 10.1142/S0218488502001648.
8. Machanavajjhala, A., Kifer, D., Gehrke, J. and Venkitasubramaniam, M., 2007. ℓ-Diversity: Privacy beyond k-anonymity. *ACM Transactions on Knowledge Discovery from Data*, 1(1), p. 3. doi: 10.1145/1217299.1217302.
9. Li, N., Li, T. and Venkatasubramanian, S., 2007. t-Closeness: Privacy beyond k-anonymity and ℓ-diversity. *Proceedings of the IEEE 23rd International Conference on Data Engineering (ICDE)*, pp. 106–115. doi: 10.1109/ICDE.2007.367856.
10. Dwork, C., McSherry, F., Nissim, K. and Smith, A., 2006. Calibrating noise to sensitivity in private data analysis. *Theory of Cryptography Conference (TCC)*, 3876, pp. 265–284. doi: 10.1007/11681878_14.
11. Dwork, C. and Roth, A., 2014. The algorithmic foundations of differential privacy. *Foundations and Trends in Theoretical Computer Science*, 9(3–4), pp. 211–407. doi: 10.1561/0400000042.

12. Zhang, J., Cormode, G., Procopiuc, C.M., Srivastava, D. and Xiao, X., 2017. PrivBayes: Private data release via Bayesian networks. *ACM Transactions on Database Systems*, 42(4), pp. 25:1–25:41. doi: 10.1145/3134428.

13. McKenna, R., Miklau, G. and Sheldon, D., 2021. Winning the NIST contest: A scalable and general approach to differentially private synthetic data. *Journal of Privacy and Confidentiality*, 11(3). doi: 10.29012/jpc.778.

14. McKenna, R., Mullins, B., Sheldon, D. and Miklau, G., 2022. AIM: An adaptive and iterative mechanism for differentially private synthetic data. *Proceedings of the VLDB Endowment*, 15(11), pp. 2599–2612. doi: 10.14778/3551793.3551817.

15. Shokri, R., Stronati, M., Song, C. and Shmatikov, V., 2017. Membership inference attacks against machine learning models. *Proceedings of the IEEE Symposium on Security and Privacy*, pp. 3–18. doi: 10.1109/SP.2017.41.

16. Yeom, S., Giacomelli, I., Fredrikson, M. and Jha, S., 2018. Privacy risk in machine learning: Analyzing the connection to overfitting. *Proceedings of the IEEE 31st Computer Security Foundations Symposium*, pp. 268–282. doi: 10.1109/CSF.2018.00027.

17. Carlini, N., Chien, S., Nasr, M., Song, S., Terzis, A. and Tramèr, F., 2022. Membership inference attacks from first principles. *Proceedings of the IEEE Symposium on Security and Privacy*, pp. 1897–1914. doi: 10.1109/SP46214.2022.9833649.

18. European Parliament and Council of the European Union, 2016. Regulation (EU) 2016/679 (General Data Protection Regulation). *Official Journal of the European Union*, L 119, pp. 1–88.

19. U.S. Department of Health and Human Services, 2002. 45 CFR § 164.514: Other requirements relating to uses and disclosures of protected health information. *Code of Federal Regulations*.

20. Government of India, 2023. *The Digital Personal Data Protection Act, 2023*. Act No. 22 of 2023. *The Gazette of India*, Extraordinary, Part II, Section 1.

21. Deng, G. et al., 2024. PentestGPT: Evaluating and harnessing large language models for automated penetration testing. *Proceedings of the 33rd USENIX Security Symposium*, pp. 847–864. doi: 10.48550/arXiv.2308.06782.

22. Ji, Z. et al., 2023. Survey of hallucination in natural language generation. *ACM Computing Surveys*, 55(12), pp. 248:1–248:38. doi: 10.1145/3571730.

23. Fung, B.C.M., Wang, K., Chen, R. and Yu, P.S., 2010. Privacy-preserving data publishing: A survey of recent developments. *ACM Computing Surveys*, 42(4), pp. 14:1–14:53. doi: 10.1145/1749603.1749605.

24. Huang, J. et al., 2024. Large language models cannot self-correct reasoning yet. *Proceedings of the 12th International Conference on Learning Representations (ICLR)*. doi: 10.48550/arXiv.2310.01798.

25. Rocher, L., Hendrickx, J.M. and de Montjoye, Y.-A., 2024. Anonymization: The imperfect science of using data while preserving privacy. *Science Advances*, 10(29), p. eadn7053. doi: 10.1126/sciadv.adn7053.

26. El Emam, K. and Dankar, F.K., 2008. Protecting privacy using k-anonymity. *Journal of the American Medical Informatics Association*, 15(5), pp. 627–637. doi: 10.1197/jamia.M2716.

27. Bayardo, R.J. and Agrawal, R., 2005. Data privacy through optimal k-anonymization. *Proceedings of the 21st International Conference on Data Engineering (ICDE)*, pp. 217–228. doi: 10.1109/ICDE.2005.42.

28. LeFevre, K., DeWitt, D.J. and Ramakrishnan, R., 2006. Mondrian multidimensional k-anonymity. *Proceedings of the 22nd International Conference on Data Engineering (ICDE)*, p. 25. doi: 10.1109/ICDE.2006.101.

29. Xu, J., Wang, W., Pei, J., Wang, X., Shi, B. and Fu, A.W., 2006. Utility-based anonymization using local recoding. *Proceedings of the 12th ACM SIGKDD International Conference on Knowledge Discovery and Data Mining*, pp. 785–790. doi: 10.1145/1150402.1150504.

30. Slijepčević, D., Henzl, M., Klausner, L.D., Dam, T., Kieseberg, P. and Zeppelzauer, M., 2021. k-Anonymity in practice: How generalisation and suppression affect machine learning classifiers. *Computers & Security*, 111, p. 102488. doi: 10.1016/j.cose.2021.102488.

31. Stadler, T., Oprisanu, B. and Troncoso, C., 2022. Synthetic data—Anonymisation groundhog day. *Proceedings of the 31st USENIX Security Symposium*, pp. 1451–1468.

32. Abadi, M. et al., 2016. Deep learning with differential privacy. *Proceedings of the ACM SIGSAC Conference on Computer and Communications Security (CCS)*, pp. 308–318. doi: 10.1145/2976749.2978318.

33. Fredrikson, M., Jha, S. and Ristenpart, T., 2015. Model inversion attacks that exploit confidence information and basic countermeasures. *Proceedings of the 22nd ACM SIGSAC Conference on Computer and Communications Security (CCS)*, pp. 1322–1333. doi: 10.1145/2810103.2813677.

34. Yao, S. et al., 2023. ReAct: Synergizing reasoning and acting in language models. *Proceedings of the 11th International Conference on Learning Representations (ICLR)*. doi: 10.48550/arXiv.2210.03629.

35. Schick, T. et al., 2023. Toolformer: Language models can teach themselves to use tools. *Advances in Neural Information Processing Systems (NeurIPS)*, 36.

36. Zheng, L. et al., 2023. Judging LLM-as-a-judge with MT-Bench and Chatbot Arena. *Advances in Neural Information Processing Systems (NeurIPS), Datasets and Benchmarks Track*, 36. doi: 10.48550/arXiv.2306.05685.

37. Min, S. et al., 2023. FActScore: Fine-grained atomic evaluation of factual precision in long form text generation. *Proceedings of the Conference on Empirical Methods in*

Natural Language Processing (EMNLP), pp. 12076–12100. doi: 10.18653/v1/2023.emnlp-main.741.

38. OpenDP, 2024. *SmartNoise synthesizers (smartnoise-synth)*. Available at: https://github.com/opendp/smartnoise-sdk.
39. Verhoeff, J., 1969. *Error Detecting Decimal Codes*. Mathematical Centre Tracts, vol. 29.
40. Brazdil, P., Giraud-Carrier, C., Soares, C. and Vilalta, R., 2009. *Metalearning: Applications to Data Mining*. Springer. doi: 10.1007/978-3-540-73263-1.
41. Becker, B. and Kohavi, R., 1996. *Adult*. UCI Machine Learning Repository. doi: 10.24432/C5XW20.
42. Kohavi, R., 1996. Scaling up the accuracy of naive-Bayes classifiers: A decision-tree hybrid. *Proceedings of the 2nd International Conference on Knowledge Discovery and Data Mining (KDD)*, pp. 202–207.
43. Janosi, A., Steinbrunn, W., Pfisterer, M. and Detrano, R., 1989. *Heart Disease*. UCI Machine Learning Repository. doi: 10.24432/C52P4X.
44. Detrano, R. et al., 1989. International application of a new probability algorithm for the diagnosis of coronary artery disease. *The American Journal of Cardiology*, 64(5), pp. 304–310. doi: 10.1016/0002-9149(89)90524-9.
45. Hofmann, H., 1994. *Statlog (German Credit Data)*. UCI Machine Learning Repository. doi: 10.24432/C5NC77.
46. Moro, S., Rita, P. and Cortez, P., 2014. *Bank Marketing*. UCI Machine Learning Repository. doi: 10.24432/C5K306.
47. Moro, S., Cortez, P. and Rita, P., 2014. A data-driven approach to predict the success of bank telemarketing. *Decision Support Systems*, 62, pp. 22–31. doi: 10.1016/j.dss.2014.03.001.
48. Clore, J., Cios, K., DeShazo, J. and Strack, B., 2014. *Diabetes 130-US Hospitals for Years 1999–2008*. UCI Machine Learning Repository. doi: 10.24432/C5230J.
49. Strack, B. et al., 2014. Impact of HbA1c measurement on hospital readmission rates: Analysis of 70,000 clinical database patient records. *BioMed Research International*, 2014, p. 781670. doi: 10.1155/2014/781670.
50. Wilcoxon, F., 1945. Individual comparisons by ranking methods. *Biometrics Bulletin*, 1(6), pp. 80–83. doi: 10.2307/3001968.
51. Holm, S., 1979. A simple sequentially rejective multiple test procedure. *Scandinavian Journal of Statistics*, 6(2), pp. 65–70.
52. Friedman, M., 1937. The use of ranks to avoid the assumption of normality implicit in the analysis of variance. *Journal of the American Statistical Association*, 32(200), pp. 675–701. doi: 10.1080/01621459.1937.10503522.
53. Demšar, J., 2006. Statistical comparisons of classifiers over multiple data sets. *Journal of Machine Learning Research*, 7, pp. 1–30.

54. McNemar, Q., 1947. Note on the sampling error of the difference between correlated proportions or percentages. *Psychometrika*, 12(2), pp. 153–157. doi: 10.1007/BF02295996.

55. Wilson, E.B., 1927. Probable inference, the law of succession, and statistical inference. *Journal of the American Statistical Association*, 22(158), pp. 209–212. doi: 10.1080/01621459.1927.10502953.

APPENDIX A – SAMPLE CODE

A.1 Strict Mondrian partitioning (engine/attacks/mondrian.py). A cut is accepted only if both halves stay k-anonymous, ℓ-diverse and t-close.

```
def mondrian(
    df: pd.DataFrame,
    qi_cols: list,
    k: int,
    sensitive: str | None = None,
    l: int | None = None,
    t: float | None = None,
) -> tuple[pd.DataFrame, list[np.ndarray]]:
    """Return (generalised copy of df, list of row-index partitions)."""
    n = len(df)
    if n < k:
        raise ValueError(f"Dataset has {n} rows, fewer than k={k}")
    codes, decoders, numeric = _prepare(df, qi_cols)
    ranges = {c: max(codes[c].max() - codes[c].min(), 1) for c in qi_cols}

    ref = Reference(df[sensitive]) if sensitive and sensitive in df.columns else None

    def allowable(idx: np.ndarray) -> bool:
        if len(idx) < k:
            return False
        if ref is None:
            return True
        part = ref.codes[idx]
        if l and len(np.unique(part[part >= 0])) < l:
            return False
        if t is not None and ref.distance_codes(part) > t:
            return False
        return True

    partitions: list[np.ndarray] = []
    stack = [np.arange(n)]
    while stack:
        idx = stack.pop()
        # Try dimensions in order of normalised span, widest first.
        spans = sorted(
            qi_cols,
            key=lambda c: (codes[c][idx].max() - codes[c][idx].min()) / ranges[c],
            reverse=True,
        )
        split = False
        for col in spans:
            vals = codes[col][idx]
            if vals.min() == vals.max():
                continue
            median = np.median(vals)
            left = idx[vals <= median]
            right = idx[vals > median]
            if len(right) == 0:  # median equals the max: cut just below it
                left, right = idx[vals < median], idx[vals >= median]
            if allowable(left) and allowable(right):
                stack.extend([left, right])
                split = True
```

A.2 Evidence gate (backend/services/agents/orchestrator.js). Attacks a verdict depends on are run if the agent skipped them.

```
function missingEvidence(done, raw) {
  const missing = [];
  if (!done.has('run_recon')) missing.push('run_recon');
  const qi = raw.profile_dataset?.schema?.quasi_identifiers;
  if ((qi === undefined || qi.length > 0) && !done.has('run_linkage'))
missing.push('run_linkage');
```

```
  return missing;
}
```

A.3 Attribute-bound grounding (backend/services/agents/grounding.js). A number is grounded only by evidence of the same metric.

```
function classify(claim, text, evidence) {
  const concepts = windowConcepts(text, claim);
  const anyValue = evidence.some((e) => valueMatches(claim, e.value));
  if (!concepts.size) return { status: anyValue ? 'grounded_unattributed' :
'ungrounded', concepts: [] };
  // Evidence whose key names no known metric cannot contradict an
  // attribution, so it may ground any claim (avoids false alarms).
  const bound = evidence.some((e) => (!e.concepts.length || e.concepts.some((c) =>
concepts.has(c))) && valueMatches(claim, e.value));
  if (bound) return { status: 'grounded', concepts: [...concepts] };
  return { status: anyValue ? 'misattributed' : 'ungrounded', concepts: [...concepts]
};
}
```

A.4 Constraint negotiation (backend/services/agents/optimizerAgent.js). Relax t, then ℓ, then the NCP cap; never k.

```
const RELAX = [
  (c) => (c.t < 0.6 ? { ...c, t: Math.round((c.t + 0.1) * 100) / 100, relaxed: 't' } :
null),
  (c) => (c.l > 1 ? { ...c, l: c.l - 1, relaxed: 'l' } : null),
  (c) => (c.max_ncp !== null ? { ...c, max_ncp: null, relaxed: 'max_ncp' } : null)
];
```

The complete source code, tests, datasets and experiment scripts are available in the project repository under the MIT licence.